

Cloud Security Risk Assessment & GRC Simulation (Azure)

A hands-on governance, risk and compliance lab: deploying a single internet-exposed Windows virtual machine in Microsoft Azure, identifying its assets, threats and vulnerabilities from the evidence the platform and the operating system provide, quantifying the resulting risk with a repeatable scoring model, and mapping each recommended control to the NIST Cybersecurity Framework and the CIS Critical Security Controls.

Objective

The objective of this project is to simulate a real-world cloud security risk assessment from a Governance, Risk and Compliance perspective, using a deliberately minimal Azure lab. By assessing a single cloud-hosted virtual machine end to end, the project covers identifying critical assets, analysing realistic threat scenarios, evaluating vulnerabilities, and quantifying risk with a structured scoring methodology. It then maps technical security controls to recognised frameworks and produces a professional GRC-style report of the kind that SOC, governance and compliance teams write in enterprise environments.

The assessment is deliberately non-exploitative. Nothing was attacked, brute-forced or exploited at any stage. Every finding comes from configuration review and native platform and operating-system logging, which is the evidence standard a GRC or internal audit function actually works to.

Lab Environment

Component	Name	Configuration
Resource Group	GRC-Lab	Region: Central India (Zone 1)
Virtual Machine	GRC-Windows-VM01	Windows 11 Pro 25H2 x64 Gen 2 (image win11-25h2-pro), Standard B2als_v2 (2 vCPU / 4 GiB), Standard SSD OS disk
Virtual Network	GRC-Windows-VM01-vnet	Subnet: default; private IP 10.1.0.4
Public IP	GRC-Windows-VM01-ip	IPv4 enabled on the NIC (address redacted); no DNS name configured
Network Security Group	GRC-Windows-VM01-nsg	Attached to the network interface only; inbound RDP (TCP/3389) allowed from Source: Any
Administrative Account	azureadmin	Local account; sole enabled account and only member of the Administrators group
Access Method	Remote Desktop Protocol	TCP/3389 over the public IP
Security Type	Trusted Launch	Secure Boot enabled, vTPM enabled, integrity monitoring disabled
Subscription	Azure for Students Starter	Identifier redacted throughout this document

Prerequisites and Tools

- Microsoft Azure subscription (free tier or student credit)
- One Azure virtual machine running Windows 11 Pro or Windows Server
- Remote Desktop (RDP) client for accessing the VM
- Spreadsheet or word processor for building the risk register and report
- Basic understanding of cybersecurity concepts: accounts, passwords, patching, logging
- No prior cloud or GRC experience required

Scope Note

This walkthrough begins at the creation of the Azure resource group. The two preliminary steps from the project brief — creating the Azure free account and signing in to the Azure portal — are intentionally omitted, because those screens contain personal billing and identity information that should not be published.

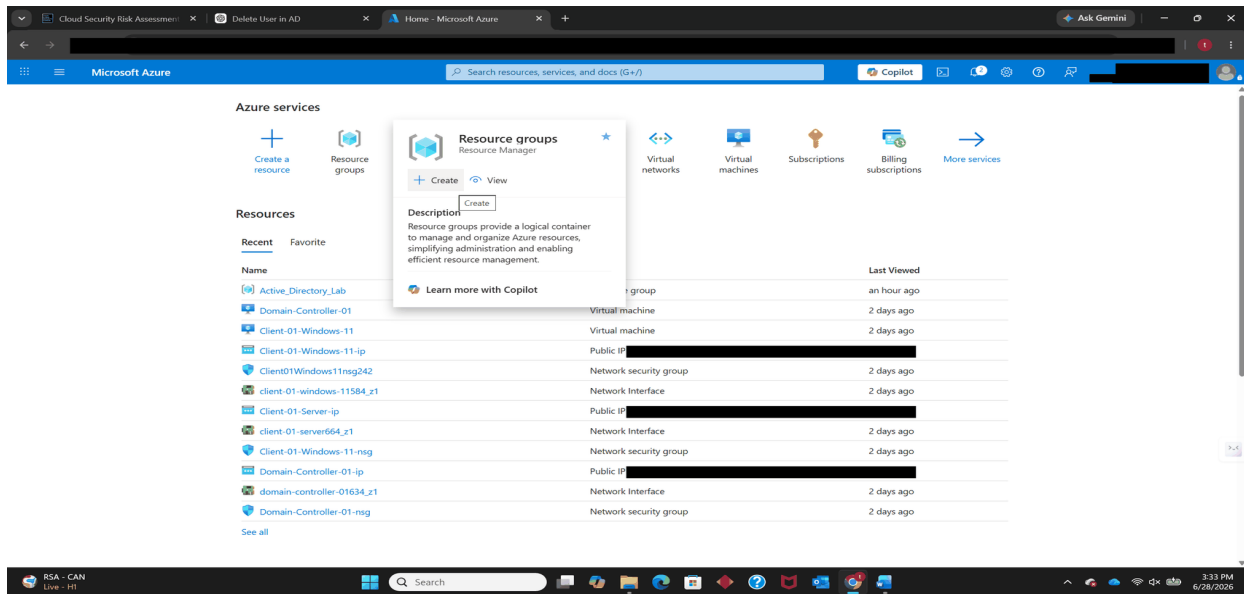
Every screenshot in this document has been redacted to remove the subscription identifier, public IP addresses, tenant and account identifiers, resource URLs and correlation IDs. The redaction is applied to the image data itself rather than laid over the top of it, so the underlying values cannot be recovered by extracting the images from this file. No credentials, RDP connection files or key material appear anywhere in this document. The environment has since been decommissioned.

In scope: the virtual machine, its network interface, network security group and public IP, the local identity store on the host, and the subscription and resource group control plane surrounding it. Out of scope: all other Azure services, applications, data classification, and any form of exploitation or penetration testing.

Step A: Create a Resource Group

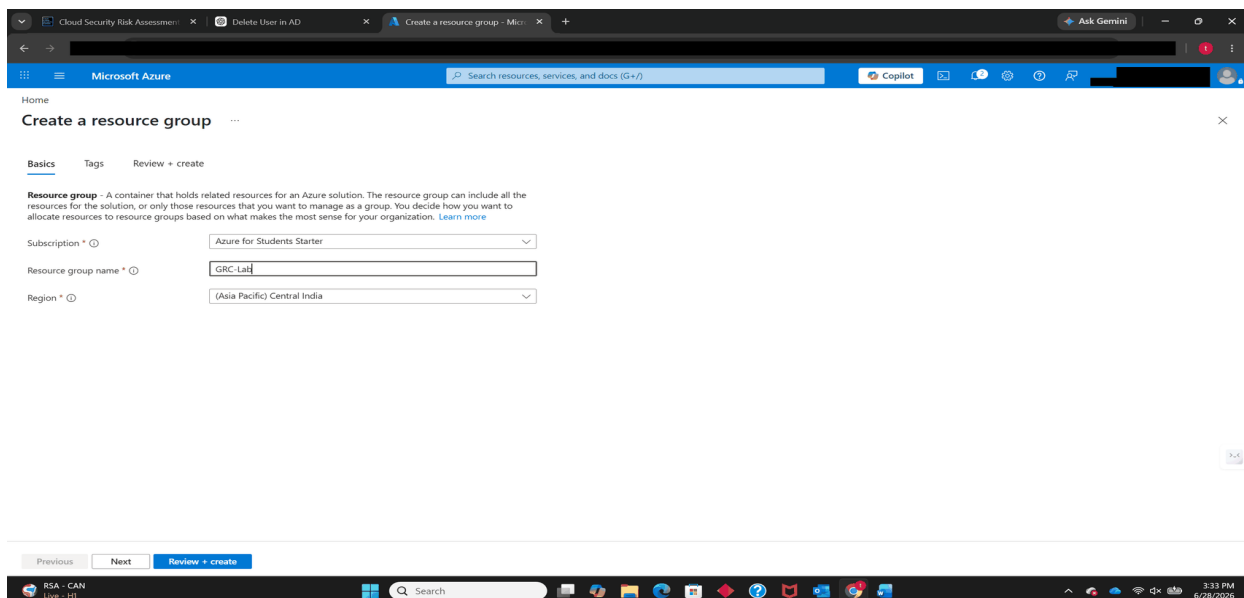
A dedicated resource group was created to hold every lab resource, so that the assessment scope had a clean boundary and teardown was a single operation.

1. Click on Create a resource

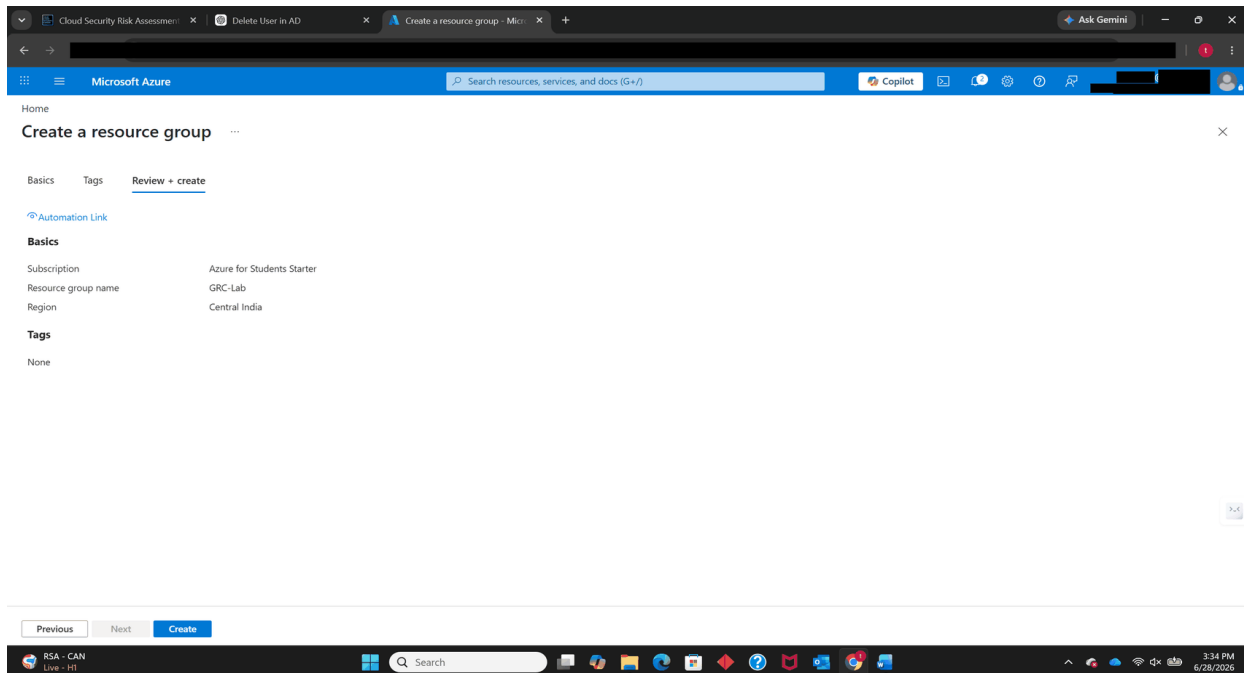


2. Configure:

- Subscription: Azure for Students Starter
- Resource Group Name: GRC-Lab
- Region: Central India, selected for proximity and lower compute cost



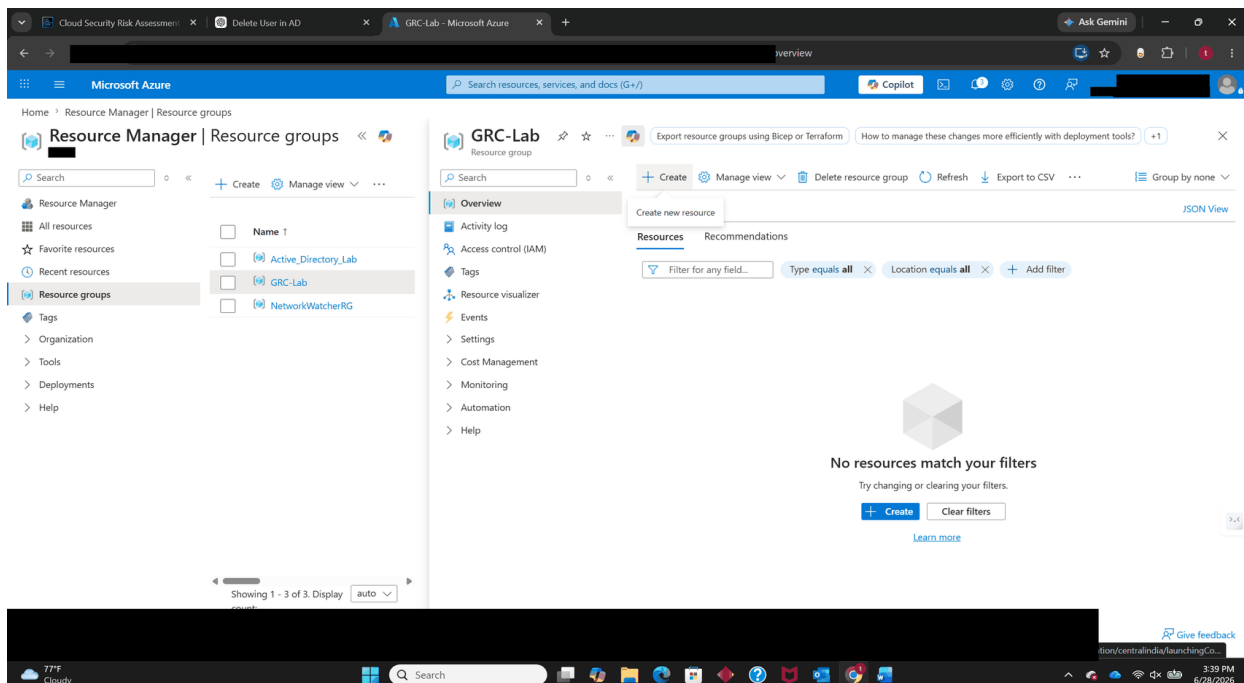
3. Click Review + Create → Create. The resource group GRC-Lab is created successfully.



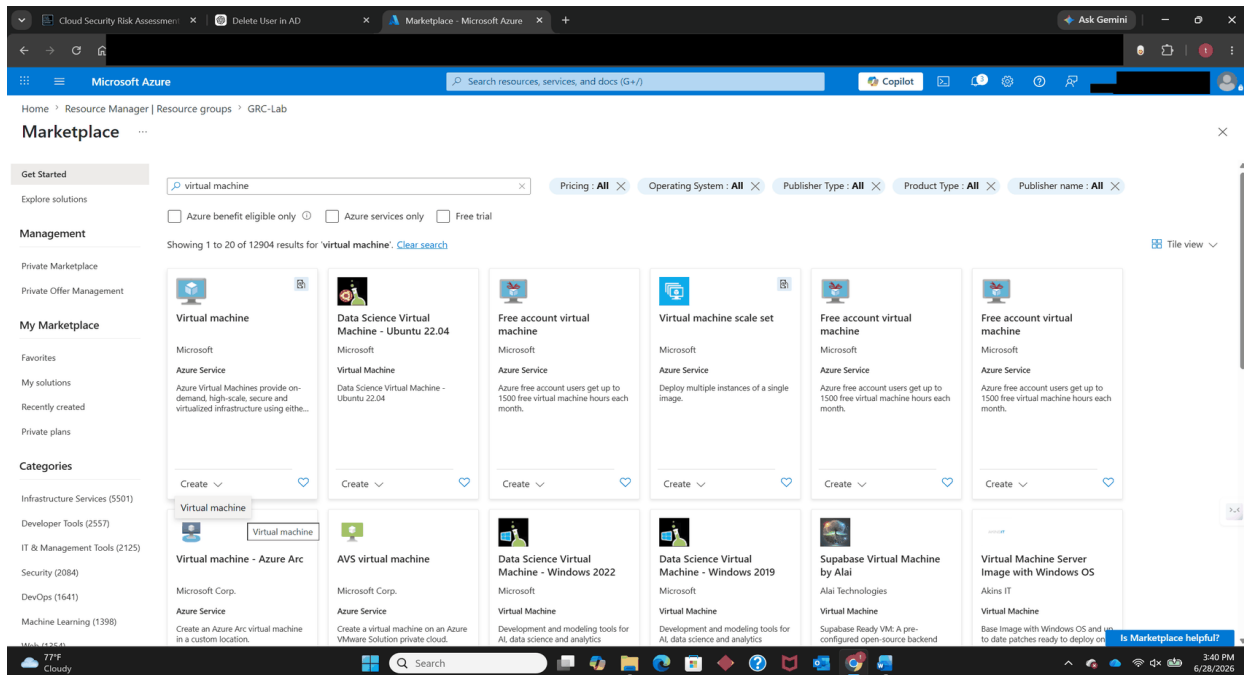
Step B: Create the Virtual Machine

A single Windows virtual machine was deployed into GRC-Lab. This VM is the entire assessment scope, in the same way that a real risk assessment for a small cloud workload would be scoped to the workload itself.

1. Click Create to create a new resource

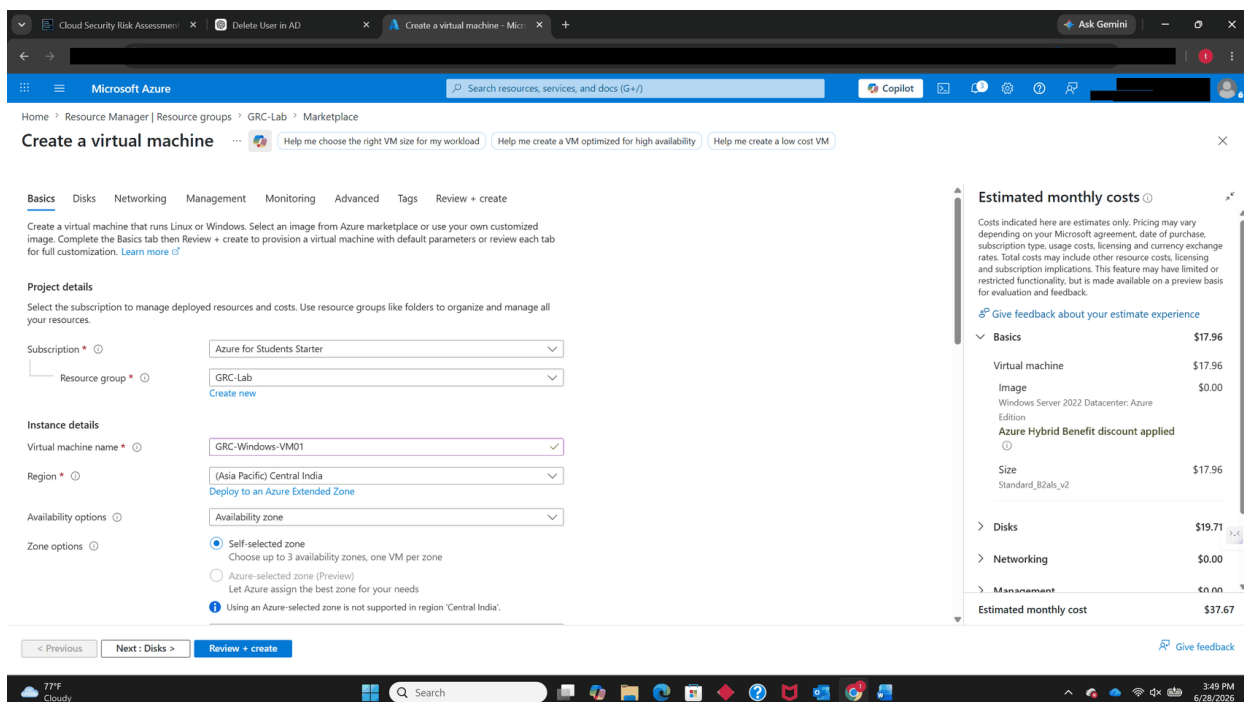


2. Search for Virtual Machine in the marketplace



3. Configure the basics:

- Resource Group: GRC-Lab
- Virtual machine name: GRC-Windows-VM01
- Region: same as the resource group



4. Select the image and size:

- OS: Windows 11 Pro, version 25H2 — x64 Gen 2
- Size: Standard B2als_v2

The screenshot shows the 'Create a virtual machine' page in the Microsoft Azure portal. The 'Image' dropdown is set to 'Windows Server 2022 Datacenter: Azure Edition - x64 Gen2'. The 'Size' dropdown is open, showing 'Standard_B2als_v2 - 2 vcpus, 4 GiB memory (\$17.96)' as the selected option. The 'Estimated monthly costs' sidebar on the right shows a total of \$37.67, including the VM (\$17.96) and disks (\$19.71).

Size B2als_v2 provides 2 vCPUs, 4 GiB RAM and 4 GiB temporary storage at roughly \$17.96 per month. It was chosen as the cheapest size that comfortably runs Windows 11 Pro for a short-lived single-VM lab; no additional compute headroom is required for a configuration-review assessment.

The screenshot shows the 'Select a VM size' page in the Microsoft Azure portal. The page displays a table of VM sizes with columns for VM Size, Type, vCPUs, RAM (GiB), Data disks, Max IOPS, Local storage (GiB), Premium disk, and Cost/month. The 'B-Series v2' section is expanded, showing various sizes like B2als_v2, B4als_v2, B8als_v2, etc. The 'B2als_v2' size is highlighted.

VM Size	Type	vCPUs	RAM (GiB)	Data disks	Max IOPS	Local storage (GiB)	Premium disk	Cost/month
B2als_v2	General purpose	2	8	4	3750	N/A	Supported	\$35.92
B4als_v2	General purpose	4	16	8	6400	N/A	Supported	\$71.83
B2als_v2	General purpose	2 (Customize)	4	4	3750	N/A	Supported	\$17.96
B2ats_v2	General purpose	2	1	4	3750	N/A	Supported	\$4.49
B2ls_v2	General purpose	2	4	4	3750	N/A	Supported	\$32.70
B2s_v2	General purpose	2	8	4	3750	N/A	Supported	\$65.41
B2ts_v2	General purpose	2	1	4	3750	N/A	Supported	\$8.18
B4als_v2	General purpose	4	8	8	6400	N/A	Supported	\$63.66
B4ls_v2	General purpose	4	8	8	6400	N/A	Supported	\$116.07
B4s_v2	General purpose	4	16	8	6400	N/A	Supported	\$130.67
B8als_v2	General purpose	8	16	16	12800	N/A	Supported	\$127.02
B8as_v2	General purpose	8	32	16	12800	N/A	Supported	\$143.81
B8ls_v2	General purpose	8	16	16	12800	N/A	Supported	\$231.41

Home > GRC-Lab > Marketplace

Create a virtual machine

Help me create a VM optimized for high availability | Help me create a low cost VM | Help me choose the right VM size for my workload

Availability options ⓘ Availability zone

Zone options ⓘ

- ☒ Self-selected zone
Choose up to 3 availability zones, one VM per zone
- ☐ Azure-selected zone (Preview)
Let Azure assign the best zone for your needs

Using an Azure-selected zone is not supported in region 'Central India'.

Availability zone * ⓘ Zone 1

You can now select multiple zones. Selecting multiple zones will create one VM per zone. [Learn more](#)

Security type ⓘ Trusted launch virtual machines
[Configure security features](#)

Image * ⓘ Windows 11 Pro, version 25H2 - x64 Gen2
[See all images](#) | [Configure VM generation](#)

VM architecture ⓘ

- ☐ Arm64
- ☒ x64

Arm64 is not supported with the selected image.

Run with Azure Spot discount ⓘ ☐

Size * ⓘ Standard_B2als_v2 - 2 vcpus, 4 GiB memory (\$17.96)
[See all sizes](#) | [Customize cores](#)

Enable Hibernation ⓘ ☐

< Previous | Next: Disks > | Review + create

Estimated monthly costs ⓘ

Costs indicated here are estimates only. Pricing may vary depending on your Microsoft agreement, date of purchase, subscription type, usage costs, licensing and currency exchange rates. Total costs may include other resource costs, licensing and subscription implications. This feature may have limited or restricted functionality, but is made available on a preview basis for evaluation and feedback.

[Give feedback about your estimate experience](#)

Basics	\$17.96
Virtual machine	\$17.96
Image	\$0.00
Windows 11 Pro, version 25H2	
Windows BYOL applied ⓘ	
Size	\$17.96
Standard_B2als_v2	
Disks	\$19.71
Networking	\$0.00
Management	\$0.00
Estimated monthly cost	\$37.67

[Give feedback](#)

5. Set up the administrator account and inbound access:

- Username and password for the local administrator account (azureadmin)
- Public inbound ports: Allow selected ports
- Selected inbound ports: RDP (3389)
- Estimated monthly cost: \$41.32

Home > GRC-Lab > Marketplace

Create a virtual machine

Help me create a VM optimized for high availability | Help me create a low cost VM | Help me choose the right VM size for my workload

Administrator account

Username * ⓘ azureadmin

Password * ⓘ *****

Confirm password * ⓘ *****

Inbound port rules

Select which virtual machine network ports are accessible from the public internet. You can specify more limited or granular network access on the Networking tab.

Public inbound ports * ⓘ

- ☐ None
- ☒ Allow selected ports

Select inbound ports * ⓘ RDP (3389)

⚠ This will allow all IP addresses to access your virtual machine. This is only recommended for testing. Use the Advanced controls in the Networking tab to create rules to limit inbound traffic to known IP addresses.

Licensing

☒ I confirm I have an eligible Windows 10/11 license with multi-tenant hosting rights. *

[Review multi-tenant hosting rights for Windows 10/11 compliance](#)

< Previous | Next: Disks > | Review + create

Estimated monthly costs ⓘ

Costs indicated here are estimates only. Pricing may vary depending on your Microsoft agreement, date of purchase, subscription type, usage costs, licensing and currency exchange rates. Total costs may include other resource costs, licensing and subscription implications. This feature may have limited or restricted functionality, but is made available on a preview basis for evaluation and feedback.

[Give feedback about your estimate experience](#)

Basics	\$17.96
Virtual machine	\$17.96
Image	\$0.00
Windows 11 Pro, version 25H2	
Windows BYOL applied ⓘ	
Size	\$17.96
Standard_B2als_v2	
Disks	\$19.71
Networking	\$0.00
Management	\$0.00
Estimated monthly cost	\$37.67

[Give feedback](#)

This is the decision that produces the two Critical findings later in this assessment, and it was made deliberately. The brief calls for an environment containing a realistic misconfiguration to assess, and RDP exposed to the internet is among the most common findings in real cloud estates. It is documented here as an intentional exposure and carried forward as risk R-01.

After filling all the details click on the “Next:Disks>” button

6. Disks: OS disk set to Standard SSD; all other settings left at their defaults.

Microsoft Azure - Create a virtual machine

Basics | **Disks** | Networking | Management | Monitoring | Advanced | Tags | Review + create

Azure VMs have one operating system disk. The size of the VM determines the type of storage you can use and the number of data disks allowed. [Learn more](#)

There is a charge for the underlying storage resources consumed by your virtual machine. [Learn more](#)

VM disk encryption
Azure disk storage encryption automatically encrypts your data stored on Azure managed disks (OS and data disks) at rest by default when persisting it to the cloud.
Encryption at host: ☐

OS disk
OS disk size:
OS disk type:
Delete with VM: ☒
Key management:
Enable Ultra Disk compatibility: ☐

Data disks for GRC-Windows-VM01
You can add and configure additional data disks for your virtual machine or attach existing disks. This VM also comes with a temporary disk.

[Previous](#) [Next: Networking >](#) [Review + create](#)

Estimated monthly costs

Costs indicated here are estimates only. Pricing may vary depending on your Microsoft agreement, date of purchase, subscription type, usage costs, licensing and currency exchange rates. Total costs may include other resource costs, licensing and subscription implications. This feature may have limited or restricted functionality, but is made available on a preview basis for evaluation and feedback.

[Give feedback about your estimate experience](#)

Basics	\$17.96
Disks	\$19.71
OS disk	\$19.71
Premium SSD, 128 GiB	
Networking	\$0.00
Management	\$0.00
Monitoring	\$0.00
Advanced	\$0.00
Estimated monthly cost	\$37.67

Microsoft Azure - Create a virtual machine

Basics | **Disks** | Networking | Management | Monitoring | Advanced | Tags | Review + create

Azure VMs have one operating system disk and a temporary disk for short-term storage. You can attach additional data disks. The size of the VM determines the type of storage you can use and the number of data disks allowed. [Learn more](#)

There is a charge for the underlying storage resources consumed by your virtual machine. [Learn more](#)

VM disk encryption
Azure disk storage encryption automatically encrypts your data stored on Azure managed disks (OS and data disks) at rest by default when persisting it to the cloud.
Encryption at host: ☐

OS disk
OS disk size:
OS disk type:
Delete with VM: ☒
Key management:
Enable Ultra Disk compatibility: ☐

Data disks for GRC-Windows-VM01
You can add and configure additional data disks for your virtual machine or attach existing disks. This VM also comes with a temporary disk.

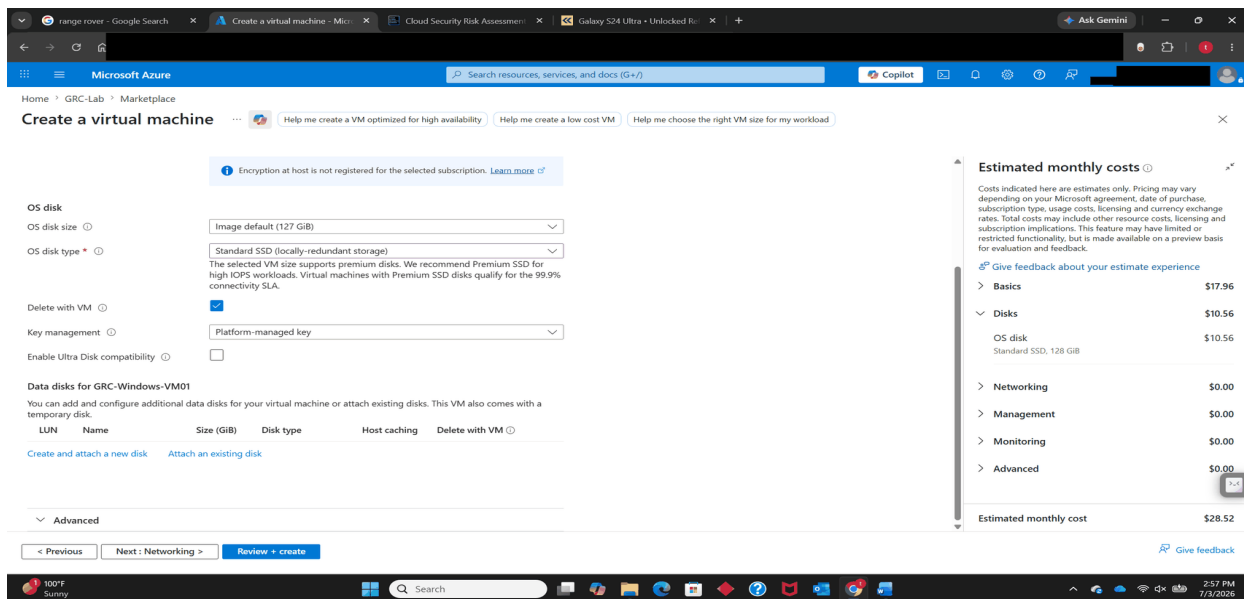
[Previous](#) [Next: Networking >](#) [Review + create](#)

Estimated monthly costs

Costs indicated here are estimates only. Pricing may vary depending on your Microsoft agreement, date of purchase, subscription type, usage costs, licensing and currency exchange rates. Total costs may include other resource costs, licensing and subscription implications. This feature may have limited or restricted functionality, but is made available on a preview basis for evaluation and feedback.

[Give feedback about your estimate experience](#)

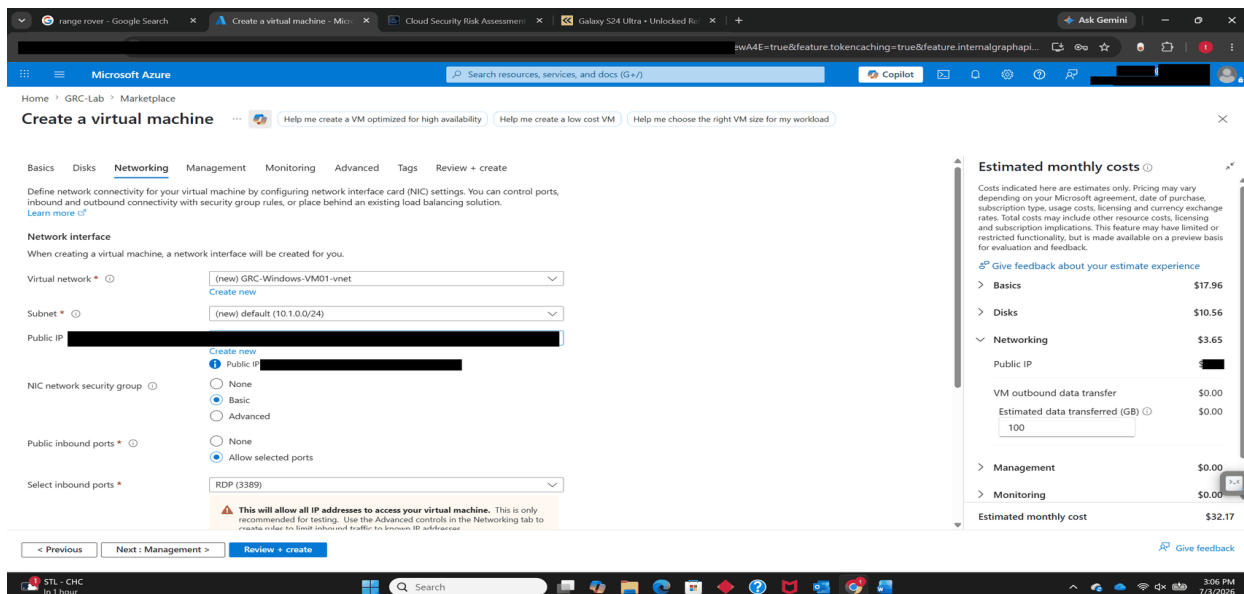
Basics	\$17.96
Disks	\$10.56
OS disk	\$10.56
Standard SSD, 128 GiB	
Networking	\$0.00
Management	\$0.00
Monitoring	\$0.00
Advanced	\$0.00
Estimated monthly cost	\$28.52

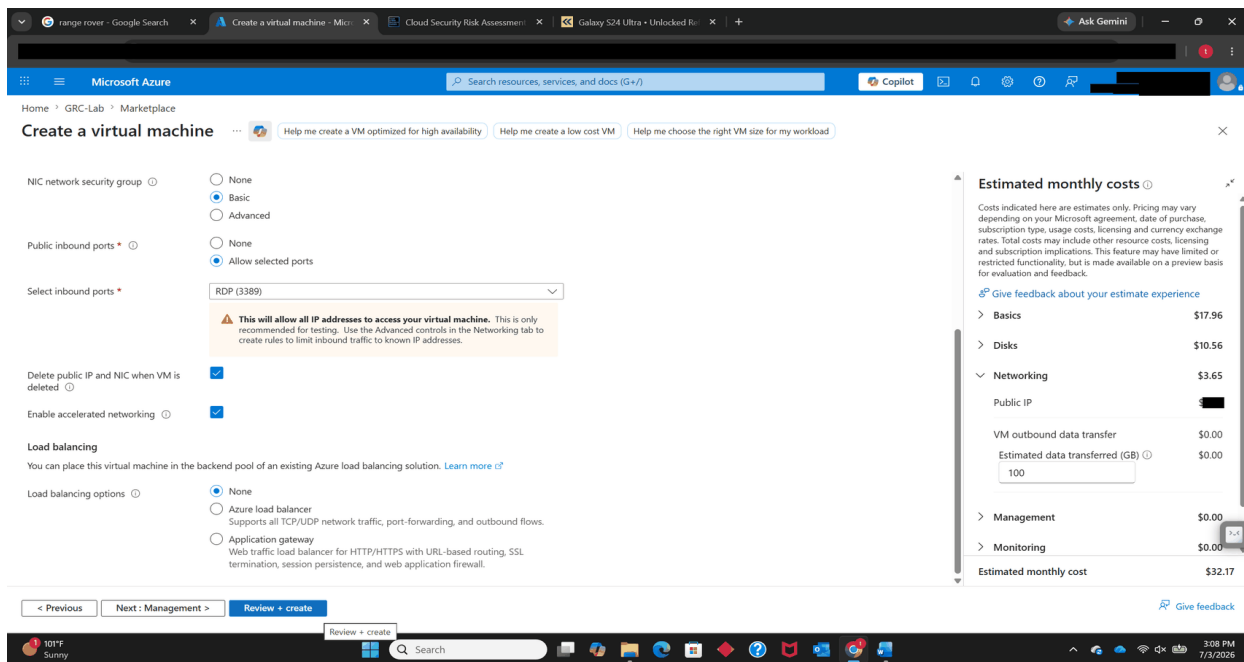


After filling all the details click on the “Next:Networking>” button

7. Networking: Azure auto-creates the virtual network, subnet, network security group and public IP.

- Virtual network: GRC-Windows-VM01-vnet
- Subnet: default
- Public IP: (new) GRC-Windows-VM01-ip
- NIC network security group: Basic
- Private IP: Static, so the address stays stable for the duration of the assessment
- Inbound ports: RDP (3389)

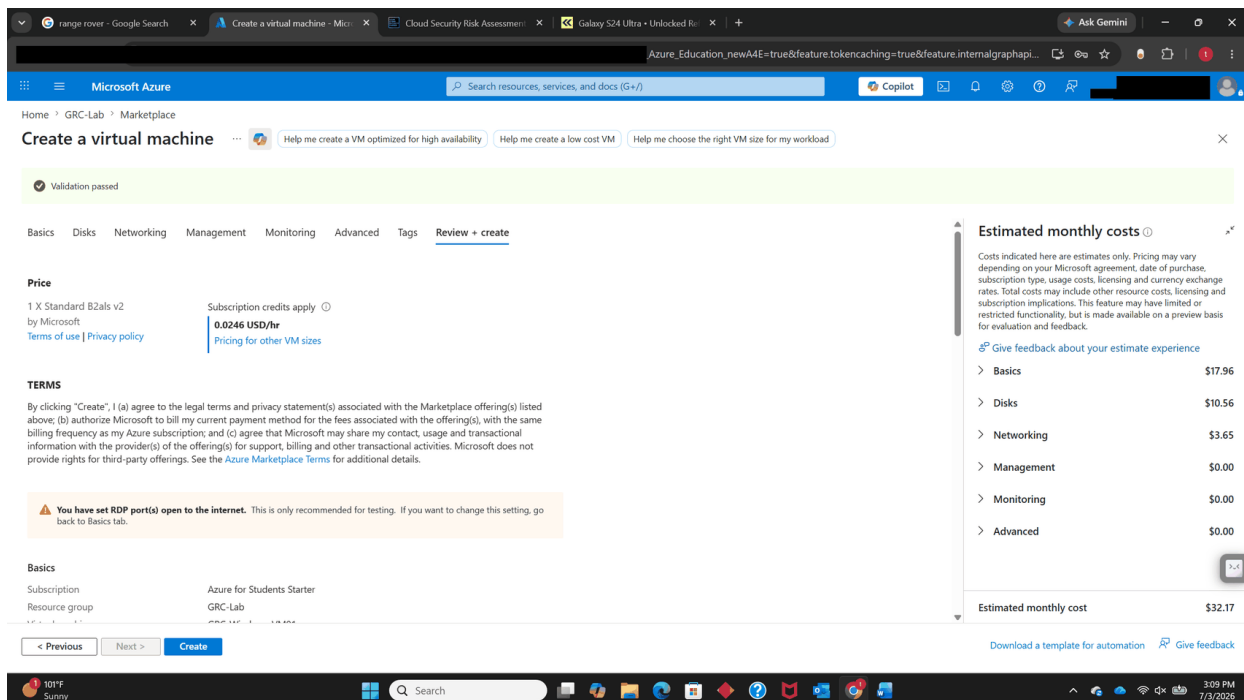




Two of these defaults matter for the assessment and are picked up in Step 1: the public IP is enabled with no bastion host in front of it, and the network security group binds to the network interface rather than to the subnet.

After filling all the details click on the “Review + create” button

8. Click Review + Create → Create.



range rover - Google Search x Create a virtual machine - Micro x Cloud Security Risk Assessment x Galaxy S24 Ultra - Unlocked R x + Ask Gemini

Microsoft Azure Search resources, services, and docs (G+/)

Home > GRC-Lab > Marketplace

Create a virtual machine

Help me create a VM optimized for high availability Help me create a low cost VM Help me choose the right VM size for my workload

Validation passed

Basics	
Subscription	Azure for Students Starter
Resource group	GRC-Lab
Virtual machine name	GRC-Windows-VM01
Region	Central India
Availability options	Availability zone
Zone options	Self-selected zone
Availability zone	1
Security type	Trusted launch virtual machines
Enable secure boot	Yes
Enable vTPM	Yes
Integrity monitoring	No
Image	Windows 11 Pro, version 25H2 - Gen2
VM architecture	x64
Size	Standard B2als v2 (2 vcpus, 4 GiB memory)
Enable Hibernation	No
Username	azureadmin
Public inbound ports	RDP
Already have a Windows license?	Yes
License type	Windows Client
Azure Spot	No

Disks

< Previous Next > Create

Estimated monthly costs

Costs indicated here are estimates only. Pricing may vary depending on your Microsoft agreement, date of purchase, subscription type, usage costs, licensing and currency exchange rates. Total costs may include other resource costs, licensing and subscription implications. This feature may have limited or restricted functionality, but is made available on a preview basis for evaluation and feedback.

[Give feedback about your estimate experience](#)

> Basics	\$17.96
> Disks	\$10.56
> Networking	\$3.65
> Management	\$0.00
> Monitoring	\$0.00
> Advanced	\$0.00

Estimated monthly cost \$32.17

[Download a template for automation](#) [Give feedback](#)

101°F Sunny 3:10 PM 7/3/2026

9. Deployment is in progress.

range rover - Google Search x Create a virtual machine - Micro x Cloud Security Risk Assessment x Galaxy S24 Ultra - Unlocked R x + Ask Gemini

Microsoft Azure Search resources, services, and docs (G+/)

Home > GRC-Lab > Marketplace

Create a virtual machine

Help me create a VM optimized for high availability Help me create a low cost VM Help me choose the right VM size for my workload

Validation passed

Disks	
OS disk size	Image default
OS disk type	Standard SSD LRS
Use managed disks	Yes
Delete OS disk with VM	Enabled
Ephemeral OS disk	No

Networking	
Virtual network	(new) GRC-Windows-VM01-vnet
Subnet	(new) default (10.1.0.0/24)
Public IP	(new) GRC-Windows-VM01-ip
Accelerated networking	On
Place this virtual machine behind an existing load balancing solution?	No
Delete public IP [redacted] deleted	Enabled

Management	
Microsoft Defender for Cloud	None
System assigned managed identity	Off
Login with Microsoft Entra ID	Off
Auto-shutdown	Off

< Previous Next > Create

Estimated monthly costs

Costs indicated here are estimates only. Pricing may vary depending on your Microsoft agreement, date of purchase, subscription type, usage costs, licensing and currency exchange rates. Total costs may include other resource costs, licensing and subscription implications. This feature may have limited or restricted functionality, but is made available on a preview basis for evaluation and feedback.

[Give feedback about your estimate experience](#)

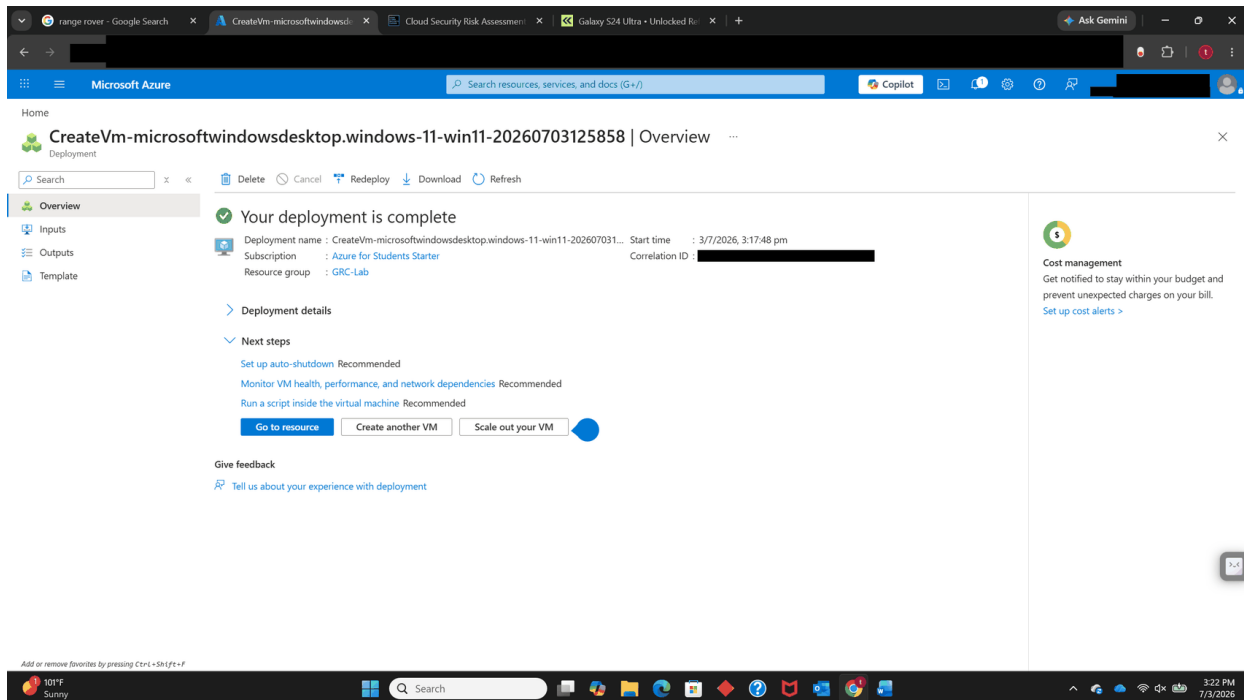
> Basics	\$17.96
> Disks	\$10.56
> Networking	\$3.65
> Management	\$0.00
> Monitoring	\$0.00
> Advanced	\$0.00

Estimated monthly cost \$32.17

[Download a template for automation](#) [Give feedback](#)

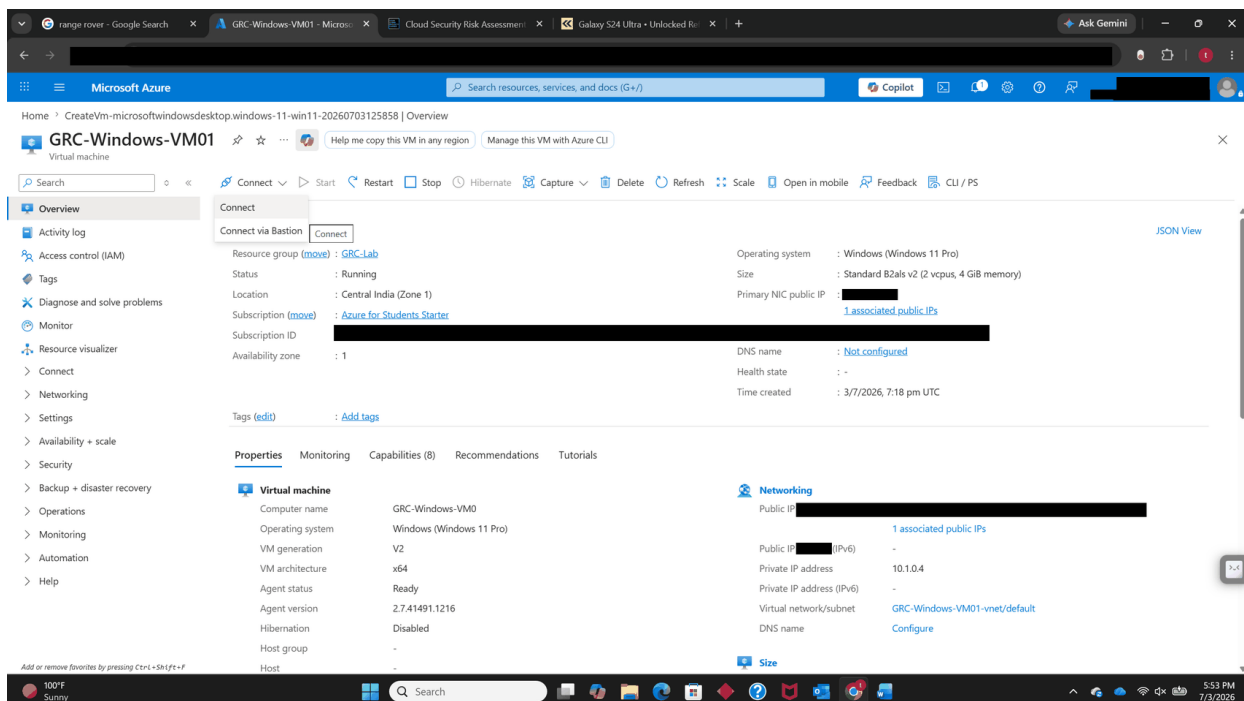
101°F Sunny 3:10 PM 7/3/2026

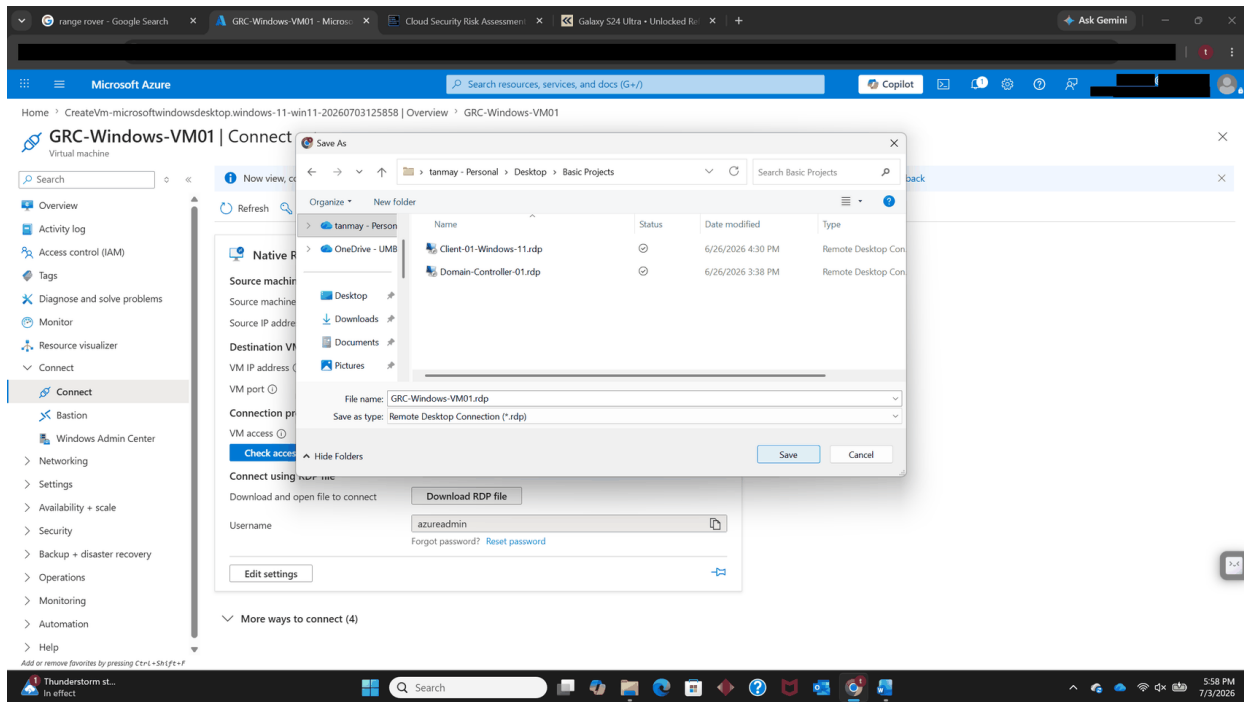
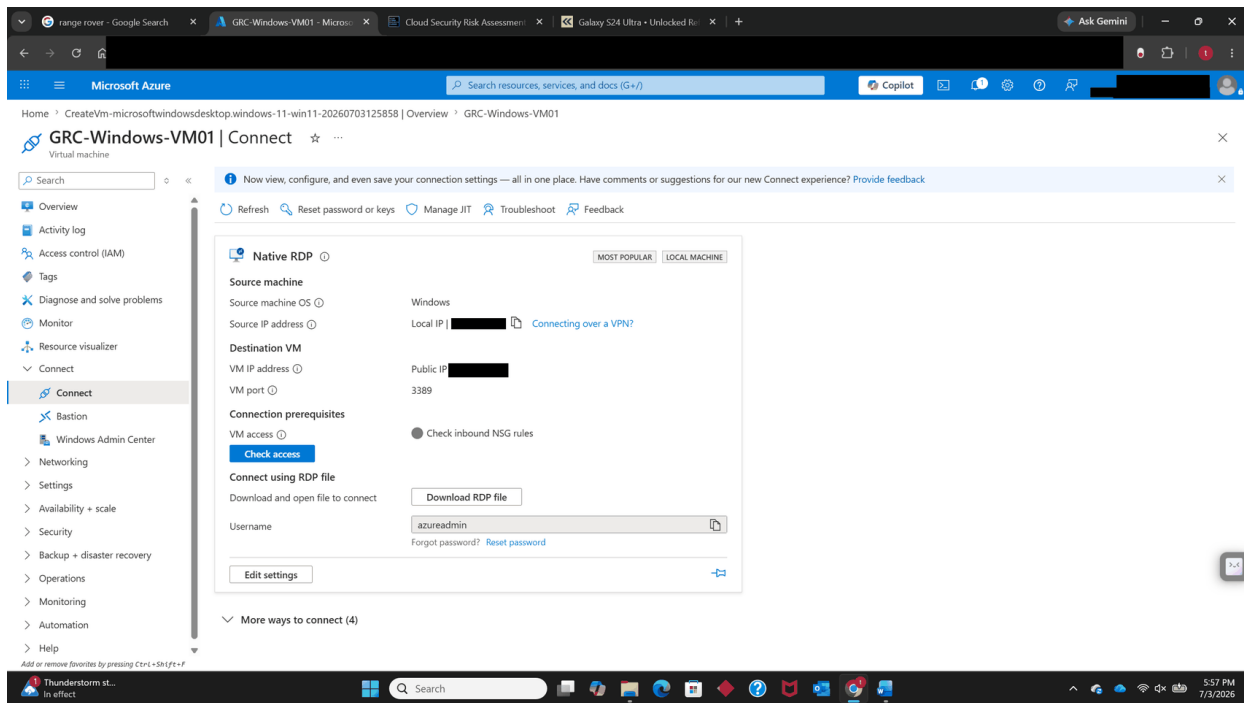
10. Deployment is complete and GRC-Windows-VM01 is running.

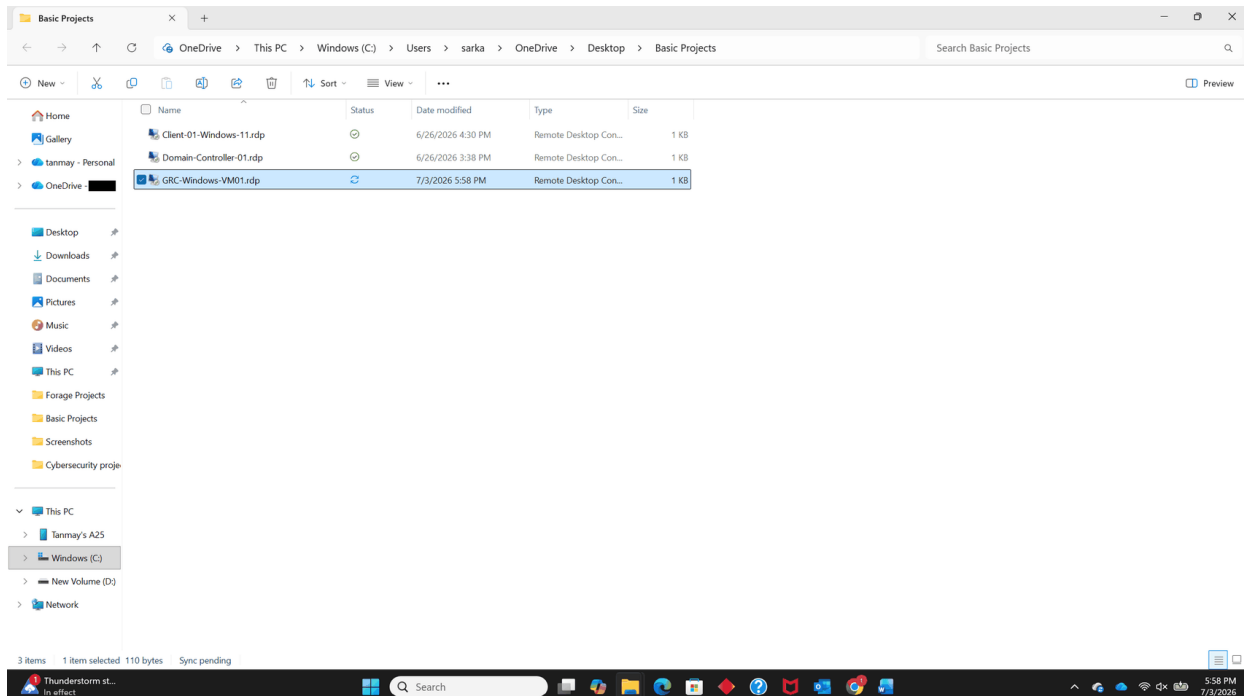
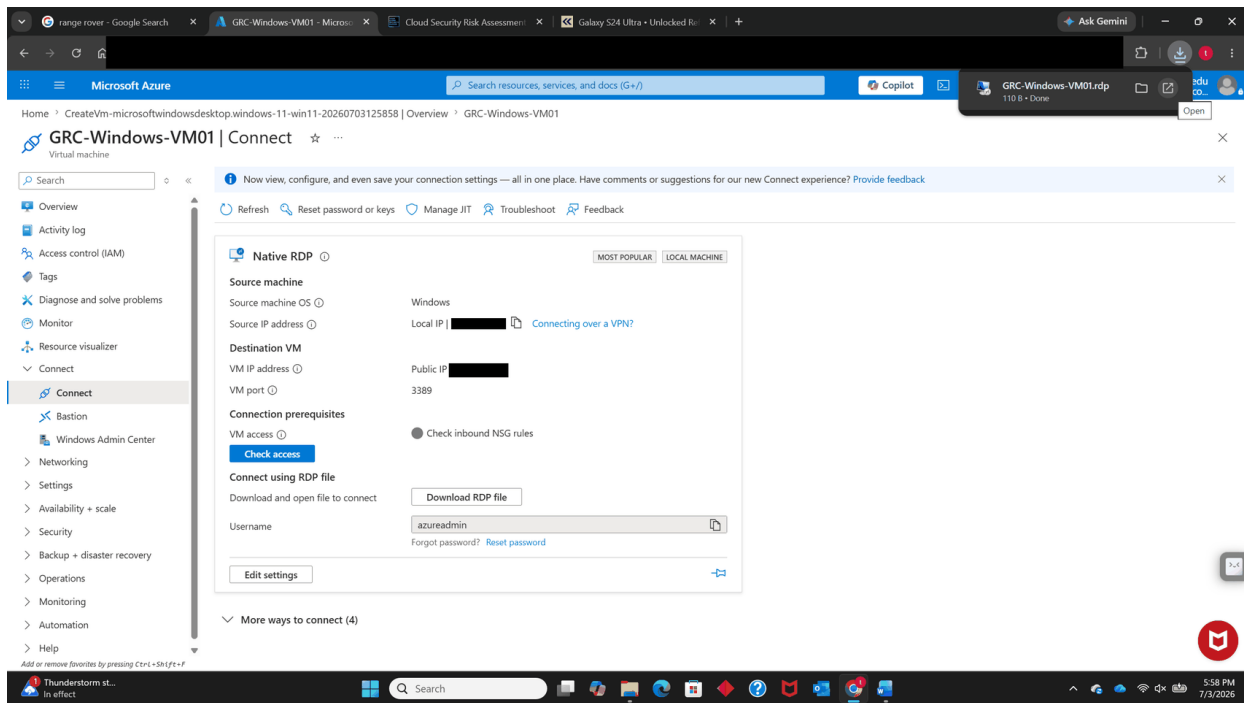


Step C: Connect to the Virtual Machine

Go to Virtual Machines → GRC-Windows-VM01 → Connect, download the RDP file and sign in with the administrator account created during deployment.







Step 1: Identify Assets, Threats and Vulnerabilities

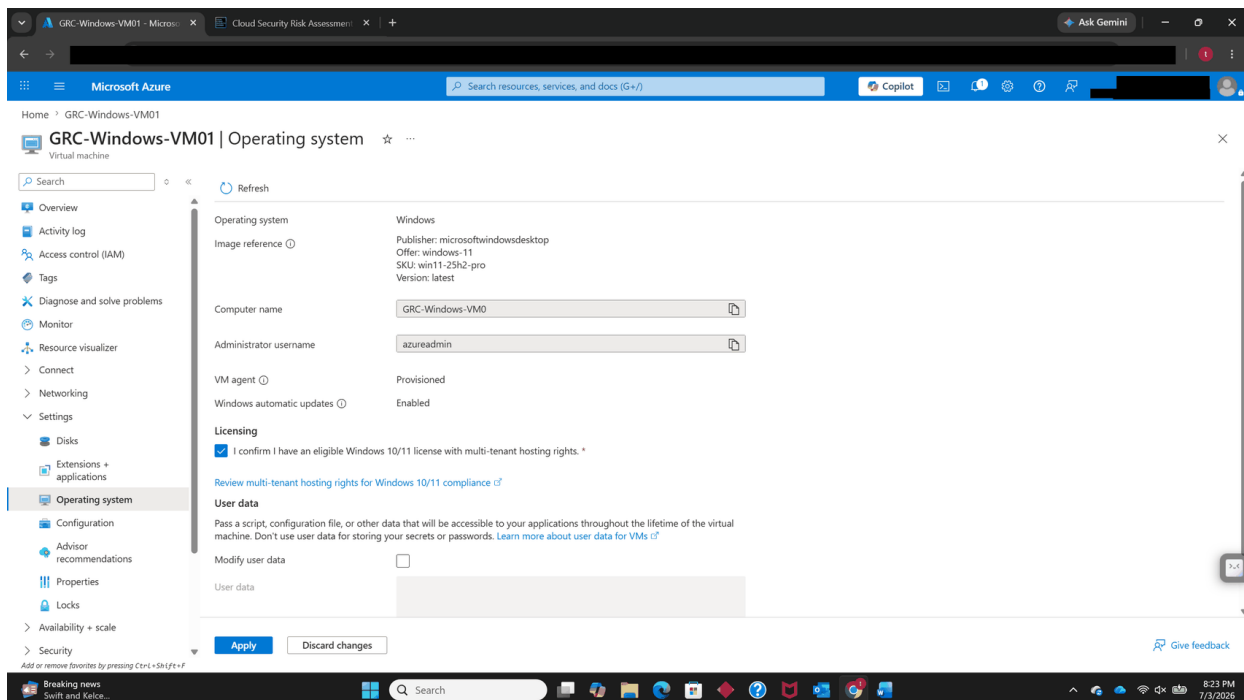
This is the most important step in a GRC assessment. If Step 1 is weak, everything built on top of it fails. It is worked in three layers and answers three questions: what do we care about, what could harm it, and why could that harm succeed?

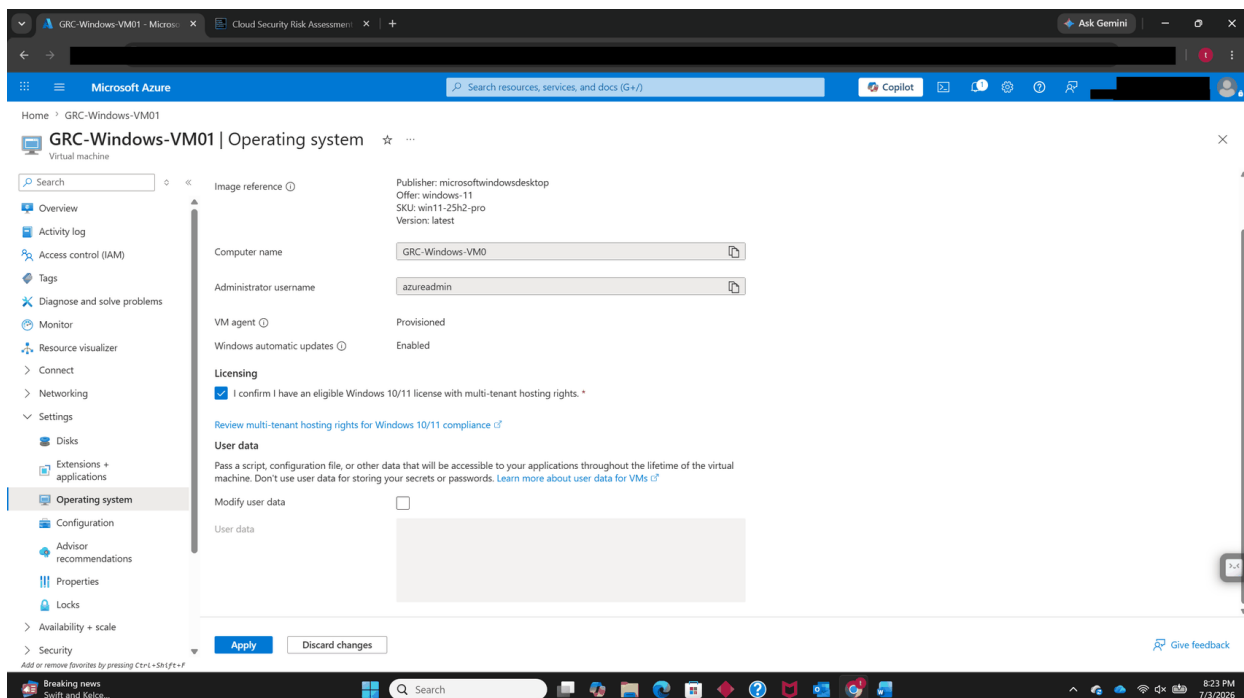
1.1 Identify Assets — what are we protecting?

Assets extend well beyond hardware. Anything that holds value, grants access, or confers privilege belongs in the inventory — accounts, network paths and cloud permissions among them. The useful test is: what would hurt if it were compromised?

Operating system

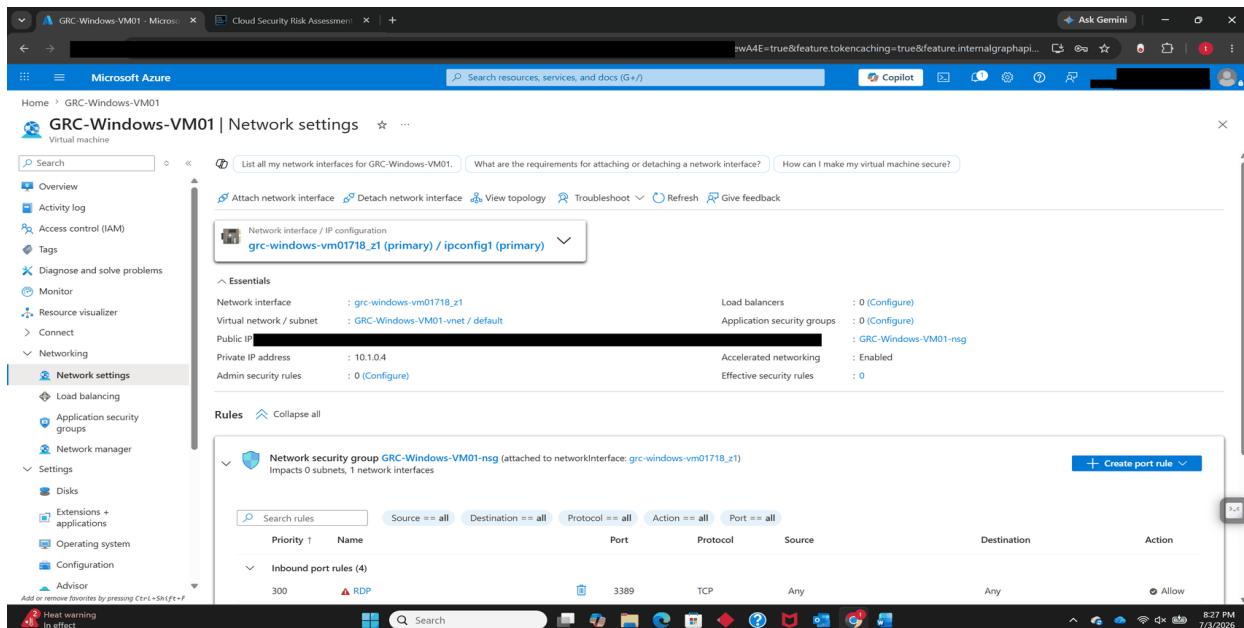
Settings → Operating System confirms the OS running on the VM, for asset inventory and risk classification: Windows 11 Pro, version 25H2, sourced from image win11-25h2-pro.

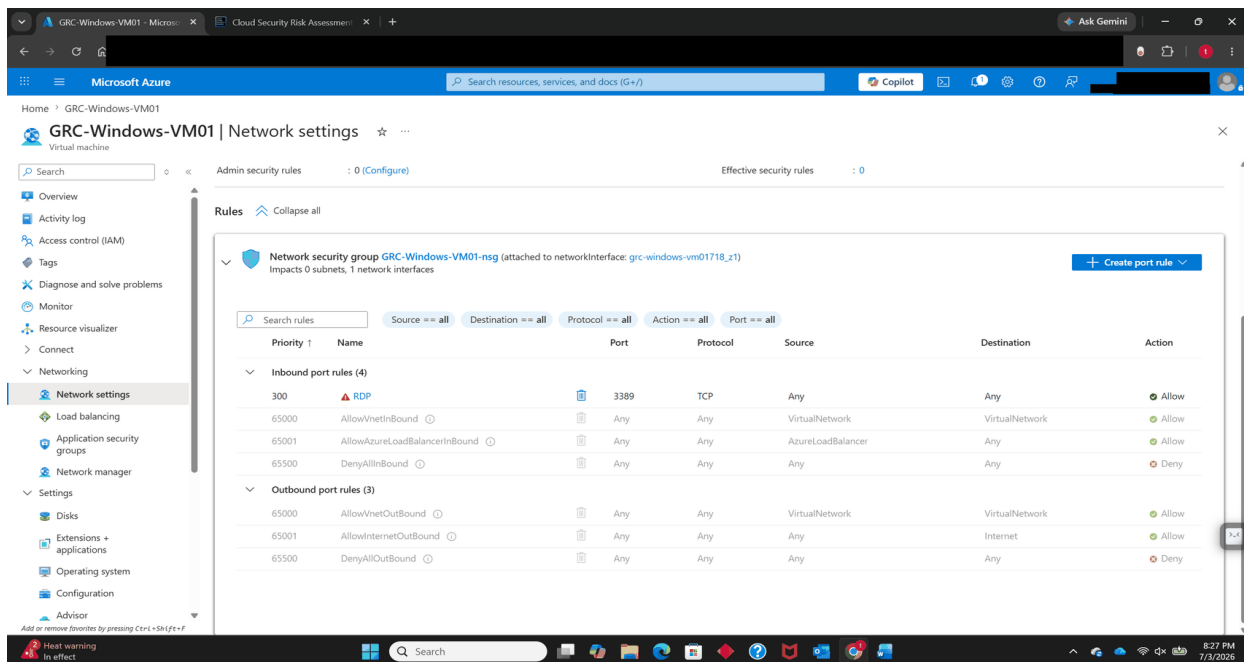




Network exposure and open ports

Networking → Network settings confirms a public IPv4 address bound to the NIC, private address 10.1.0.4, and no DNS name configured. Rules → open ports identifies the externally accessible services that make up the attack surface.





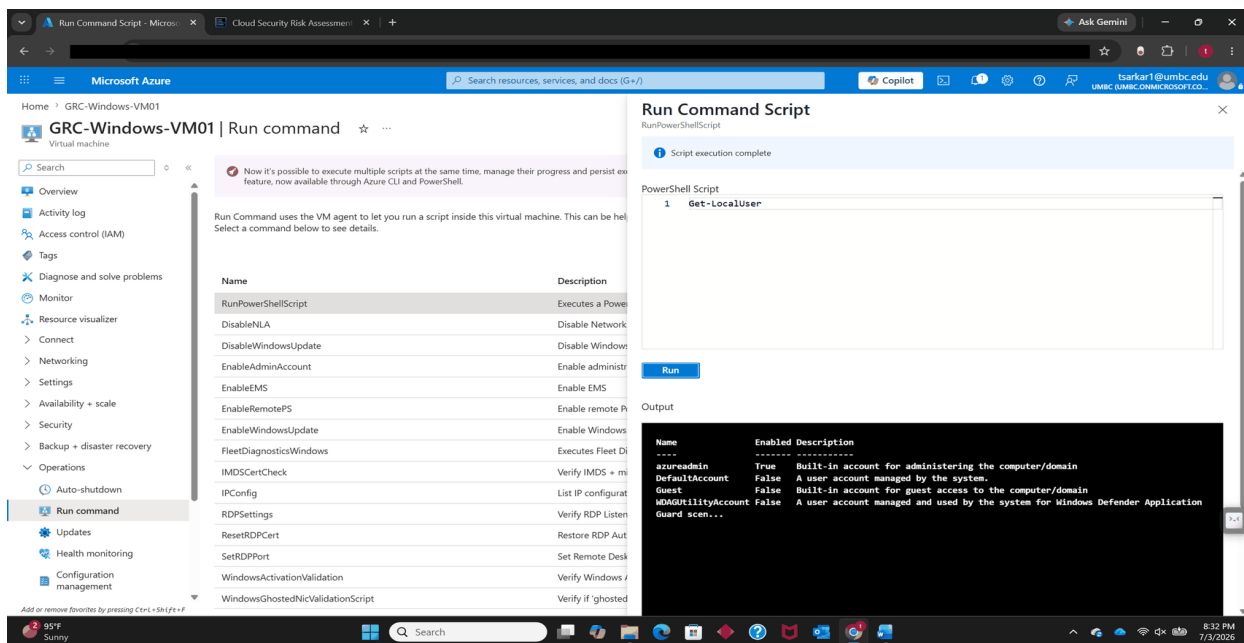
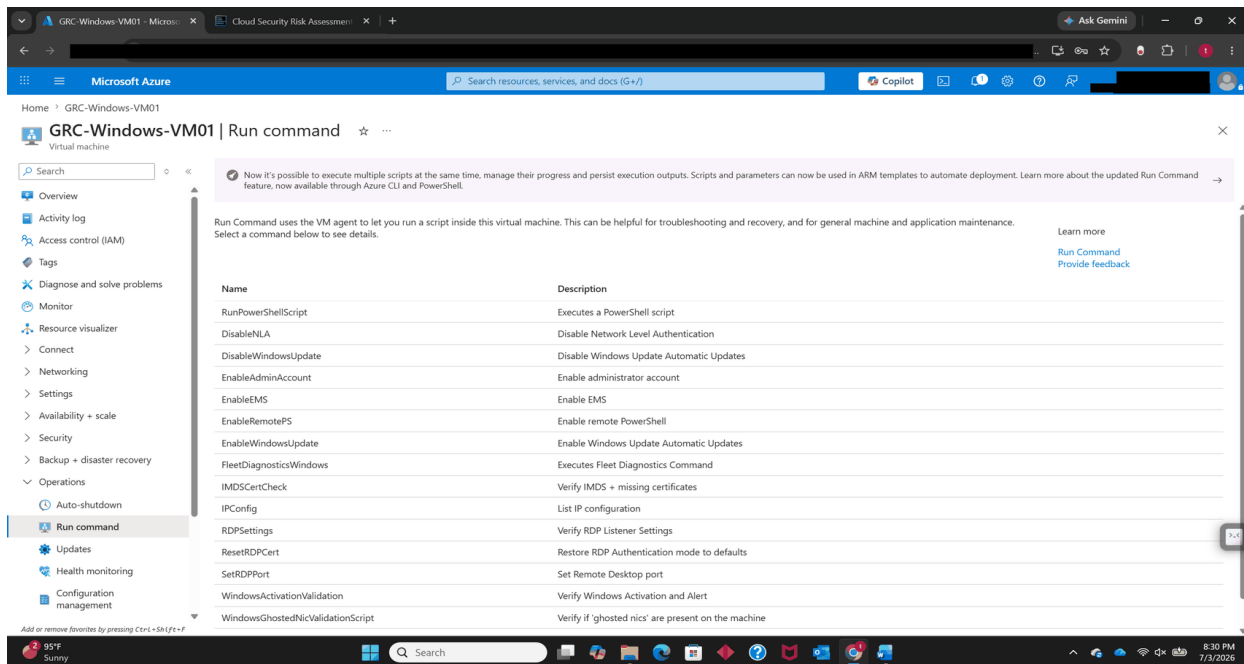
The inbound rule set on GRC-Windows-VM01-nsg reads as follows.

Priority	Name	Port	Protocol	Source	Action
300	RDP	3389	TCP	Any	Allow
65000	AllowVnetInBound	Any	Any	VirtualNetwork	Allow
65001	AllowAzureLoadBalancerInBound	Any	Any	AzureLoadBalancer	Allow
65500	DenyAllInBound	Any	Any	Any	Deny

Three observations come from this single screen. Rule 300 permits RDP from any source address on the internet, and Azure marks the rule with a warning icon of its own accord. The NSG header reads "Impacts 0 subnets, 1 network interface" and effective security rules is 0, meaning the NSG protects the interface only and there is no subnet-level control behind it. And outbound rule 65001, AllowInternetOutBound, permits unrestricted egress to the internet.

Privileged accounts

Operations → Run command → RunPowerShellScript was used to run Get-LocalUser, which enumerates local accounts without needing an interactive session on the host.



Account	Enabled	Description
azureadmin	True	Built-in account for administering the computer/domain
DefaultAccount	False	A user account managed by the system
Guest	False	Built-in account for guest access to the computer/domain
WDAGUtilityAccount	False	Managed by the system for Windows Defender Application Guard

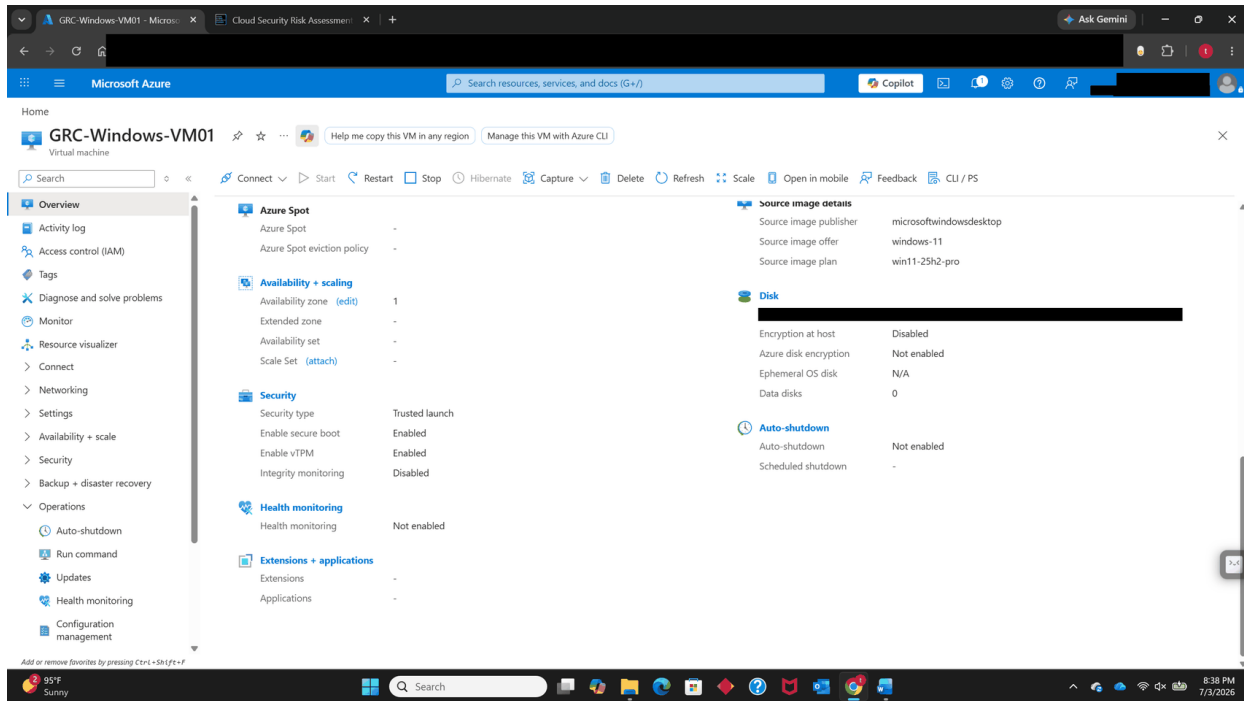
azureadmin is the only enabled account on the host. Every administrative action therefore traces back to one shared identity, so the audit trail carries no individual accountability.

Public exposure and platform security posture

The VM overview confirms the machine is reachable from the internet and surfaces several platform settings that feed directly into the risk register.

The screenshot shows the Microsoft Azure portal interface. The top navigation bar includes the Azure logo, a search bar, and a user profile. The main content area is titled "GRC-Windows-VM01" and shows the "Overview" tab. The left sidebar contains a navigation menu with options like "Activity log", "Access control (IAM)", "Tags", "Diagnose and solve problems", "Monitor", "Resource visualizer", "Connect", "Networking", "Settings", "Availability + scale", "Security", "Backup + disaster recovery", and "Operations". The main content area is divided into two columns. The left column, titled "Essentials", shows the resource group "GRC-Lab", status "Running", location "Central India (Zone 1)", subscription "Azure for Students Starter", and availability zone "1". The right column, titled "Properties", shows the operating system "Windows (Windows 11 Pro)", size "Standard B2als v2 (2 vcpus, 4 GiB memory)", primary NIC public IP, DNS name "Not configured", health state, and time created "3/7/2026, 7:18 pm UTC". Below these are tabs for "Properties", "Monitoring", "Capabilities (8)", "Recommendations", and "Tutorials". The "Properties" tab is active, showing details for the virtual machine, including computer name, operating system, VM generation, VM architecture, agent status, agent version, hibernation, host group, and host. The "Networking" section shows the public IP, private IP address, and virtual network/subnet. The "Size" section shows the size, vCPUs, RAM, and threads per core. The "Source image details" section shows the source image publisher, source image offer, and source image plan. The "Disk" section shows the OS disk and encryption at host.

The screenshot shows the Microsoft Azure portal interface. The top navigation bar includes the Azure logo, a search bar, and a user profile. The main content area is titled "GRC-Windows-VM01" and shows the "Properties" tab. The left sidebar contains a navigation menu with options like "Activity log", "Access control (IAM)", "Tags", "Diagnose and solve problems", "Monitor", "Resource visualizer", "Connect", "Networking", "Settings", "Availability + scale", "Security", "Backup + disaster recovery", and "Operations". The main content area is divided into two columns. The left column, titled "Virtual machine", shows the computer name "GRC-Windows-VM0", operating system "Windows (Windows 11 Pro)", VM generation "V2", VM architecture "x64", agent status "Ready", agent version "2.7.41491.1216", hibernation "Disabled", host group, and host. The right column, titled "Networking", shows the public IP, private IP address, private IP address (IPv6), virtual network/subnet, and DNS name. The "Size" section shows the size "Standard B2als v2", vCPUs "2", RAM "4 GiB", and threads per core "2". The "Source image details" section shows the source image publisher "microsoftwindowsdesktop", source image offer "windows-11", and source image plan "win11-25H2-pro". The "Disk" section shows the OS disk and encryption at host. The "Availability + scaling" section shows the availability zone "1" and extended zone.



Setting	Observed state	Feeds risk
Public IP	Enabled	R-01
Security type	Trusted Launch	—
Secure Boot / vTPM	Enabled	—
Integrity monitoring	Disabled	R-09
Encryption at host	Disabled	R-09
Azure Disk Encryption	Not enabled	R-09
Health monitoring	Not enabled	R-04
Backup + disaster recovery	Not configured	R-08
Extensions	None installed	R-03

Worth stating precisely, because it affects the score: Azure managed disks are encrypted at rest by default using platform-managed keys, so "Azure Disk Encryption: Not enabled" does not mean the disk is plaintext. The residual gap is customer key ownership and the absence of attestation alerting, which is why R-09 is scored Low rather than inflated for effect.

Identified assets

The nine assets below were catalogued from the evidence above, each rated for the confidentiality, integrity and availability it carries. Rating each asset this way is what allows impact to be scored consistently in Step 2 rather than guessed per finding.

Identified Assets						
ID	Category	Asset	Why It Matters	C	I	A
A-01	Compute	Azure VM GRC-Windows-VM01	Hosts the operating system and every service in scope; compromise of the host compromises everything below it	High	High	Med
A-02	Identity	Local administrator azureadmin	Administrators have complete and unrestricted access; the highest-value target on the host	High	High	High
A-03	Network	Public IP on the VM NIC	Makes the workload directly reachable from the internet, turning a local weakness into a remote one	Med	Med	High
A-04	Network	RDP service, TCP/3389	The single authenticated entry path into the host and the most attacked management port on the internet	High	High	High
A-05	Network	NSG GRC-Windows-VM01-nsg	The only network access control present; its scope of attachment decides whether it can contain lateral movement	Low	High	Med
A-06	Cloud control	Subscription and GRC-Lab group	Control-plane access permits snapshot, extension execution and deletion — it outranks any control inside the guest OS	High	High	High
A-07	Data	OS disk (managed, Standard SSD)	Holds the operating system, credential material and any files created during the assessment	Med	Med	Med
A-08	Logging	Windows Security event log	The only record of who authenticated and when; without it there is no incident timeline	Med	High	Low
A-09	Monitoring	Azure platform metrics	Partial coverage creates false assurance: performance data is present while security telemetry is not	Low	Med	Med

Assets are not limited to servers. Accounts, access pathways and cloud permissions all appear above, because each of them holds value, grants access or confers privilege.

1.2 Identify Threats — what could realistically go wrong?

Threats are assessed against real attack patterns seen in enterprise environments rather than theoretical ones: who would attack this, how would they reach it, and what techniques are common in the wild?

Threats can be external or internal, and GRC addresses both.

Identified Threats		
Asset	Threat Scenario	Why It Is Realistic
Public RDP endpoint (TCP/3389)	Automated brute-force and password spray from the internet	RDP is the most scanned management port on the internet; exposure is found within hours
azureadmin administrator account	Credential compromise giving interactive administrative access	Predictable account name protected by a single factor
Windows 11 Pro guest OS	Exploitation of a known unpatched vulnerability	Public exploits follow disclosure within days on unmanaged hosts
Azure subscription and resource group	Unauthorised configuration change, snapshot exfiltration or deletion	Control-plane access outranks every control inside the guest OS
Windows Security event log	Malicious activity proceeding undetected	Logs held only on the host, with no alerting, are never read

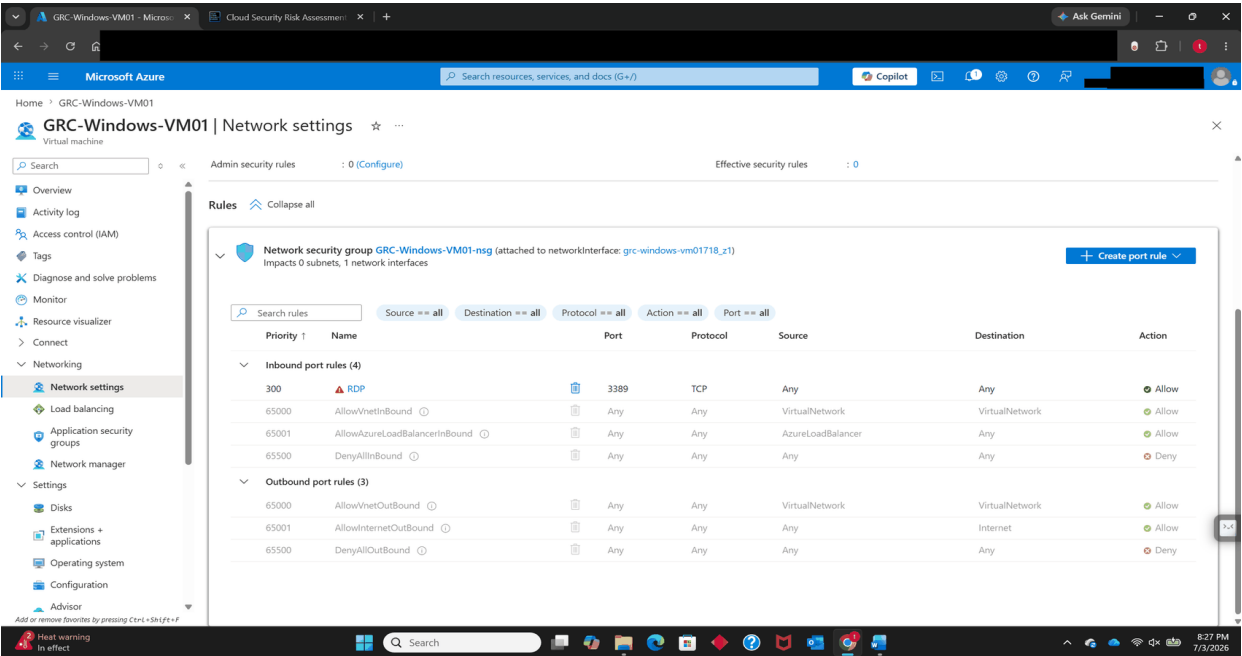
Outbound network path	Command-and-control channel or data exfiltration	Default Azure rules permit unrestricted egress
VM availability	Destructive attack or accidental deletion	No backup means no recovery point exists

1.3 Identify Vulnerabilities — why the threat could work

A vulnerability is a weakness, not an attack. Nothing here required exploitation to establish: if a configuration can be abused, it is documented as a vulnerability. A vulnerability does not require proof of exploitation.

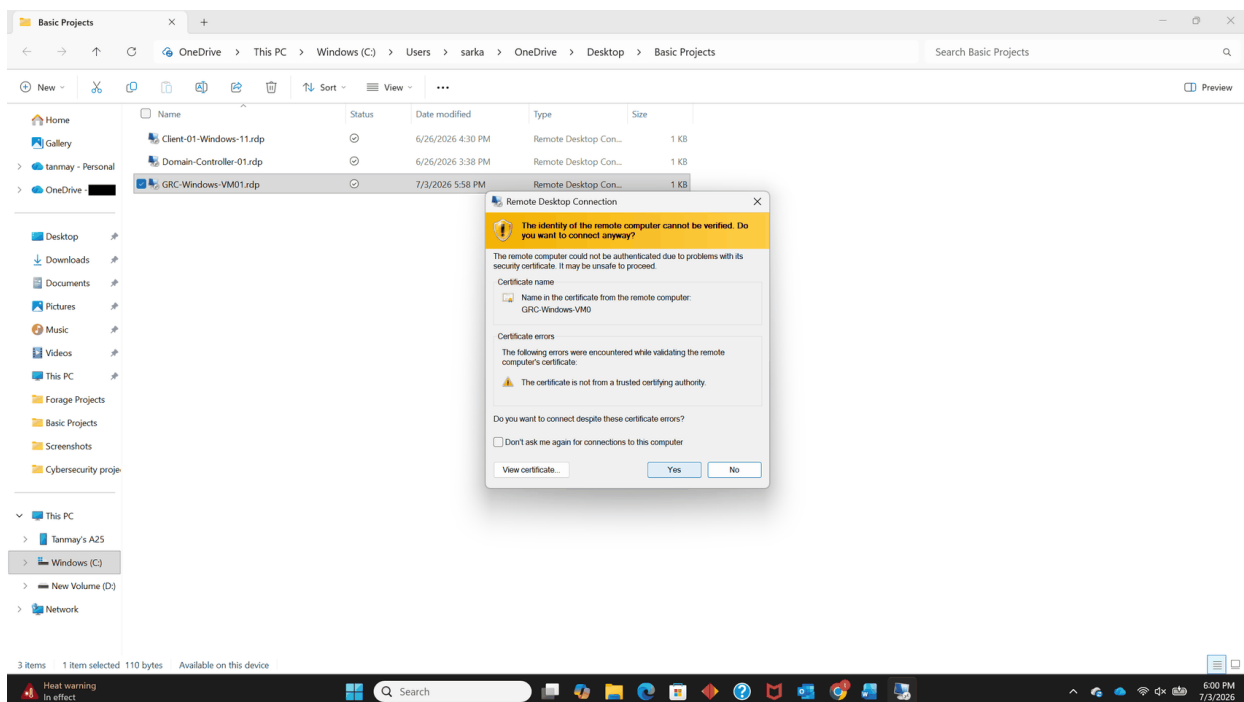
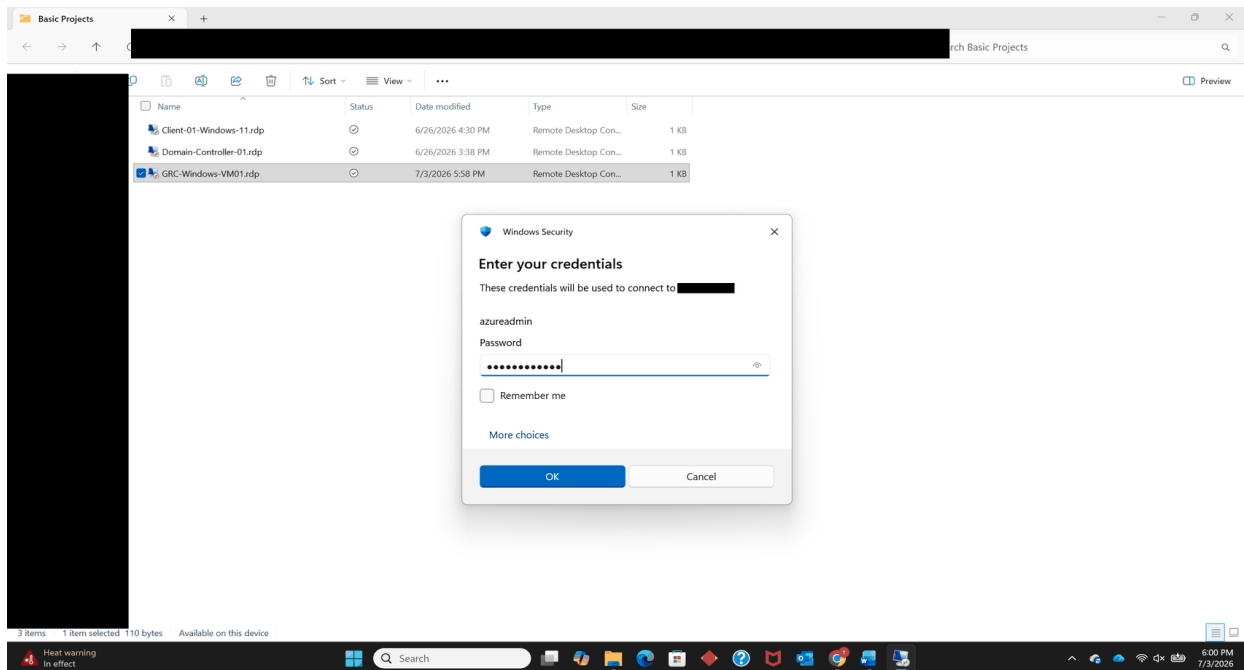
Network security group review

In GRC-Windows-VM01 → Networking → Network settings, the inbound rules were reviewed. RDP (TCP/3389) is allowed with the source set to Any and the action set to Allow. Allowing RDP to the internet materially increases the risk of brute-force and credential-based attack and is documented here as the primary vulnerability behind R-01.



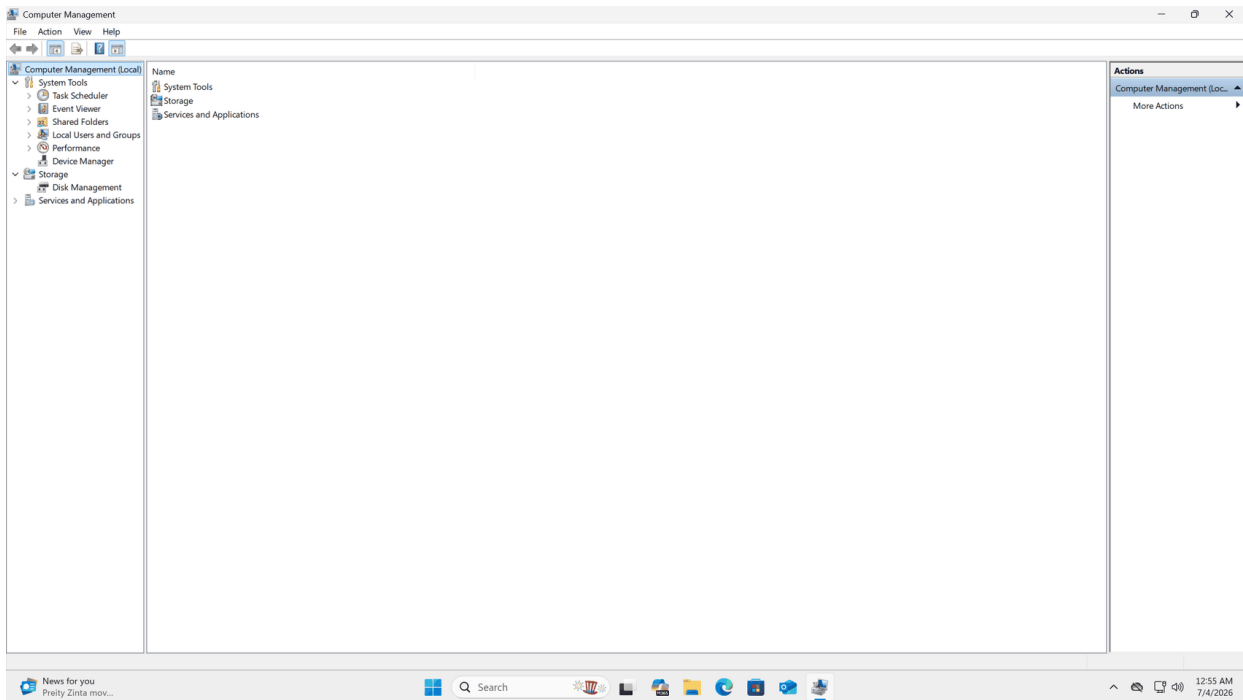
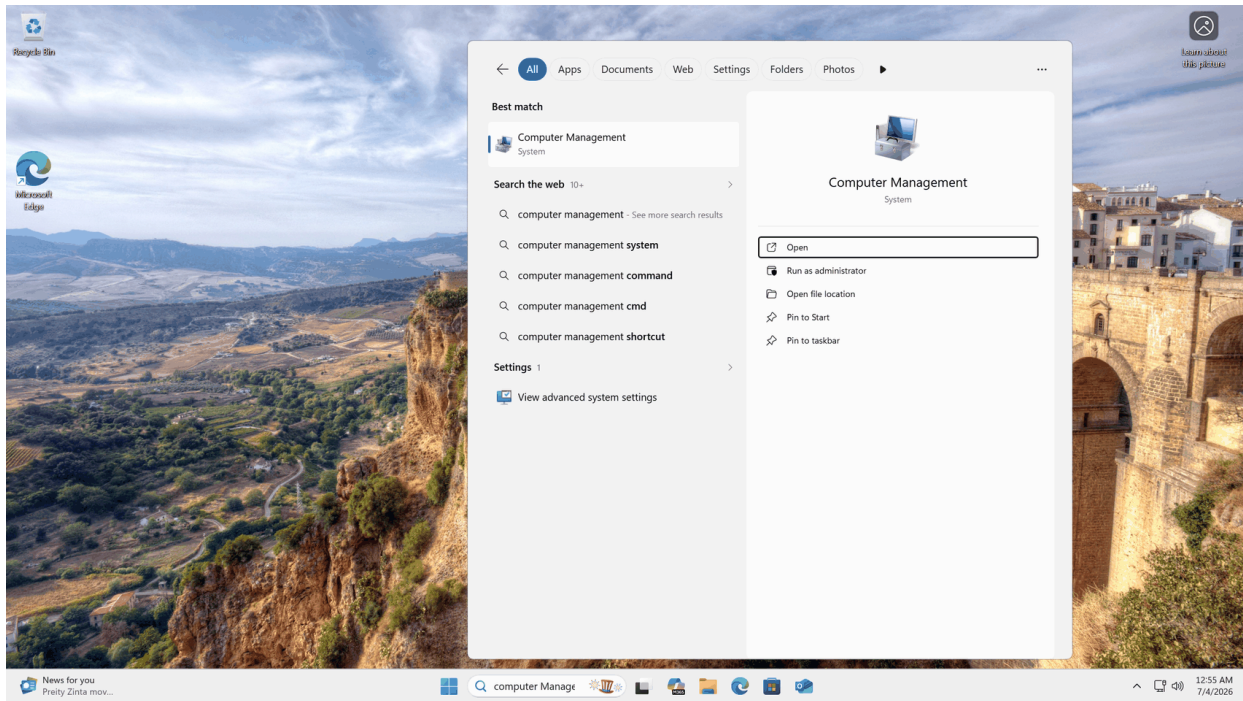
Authentication method

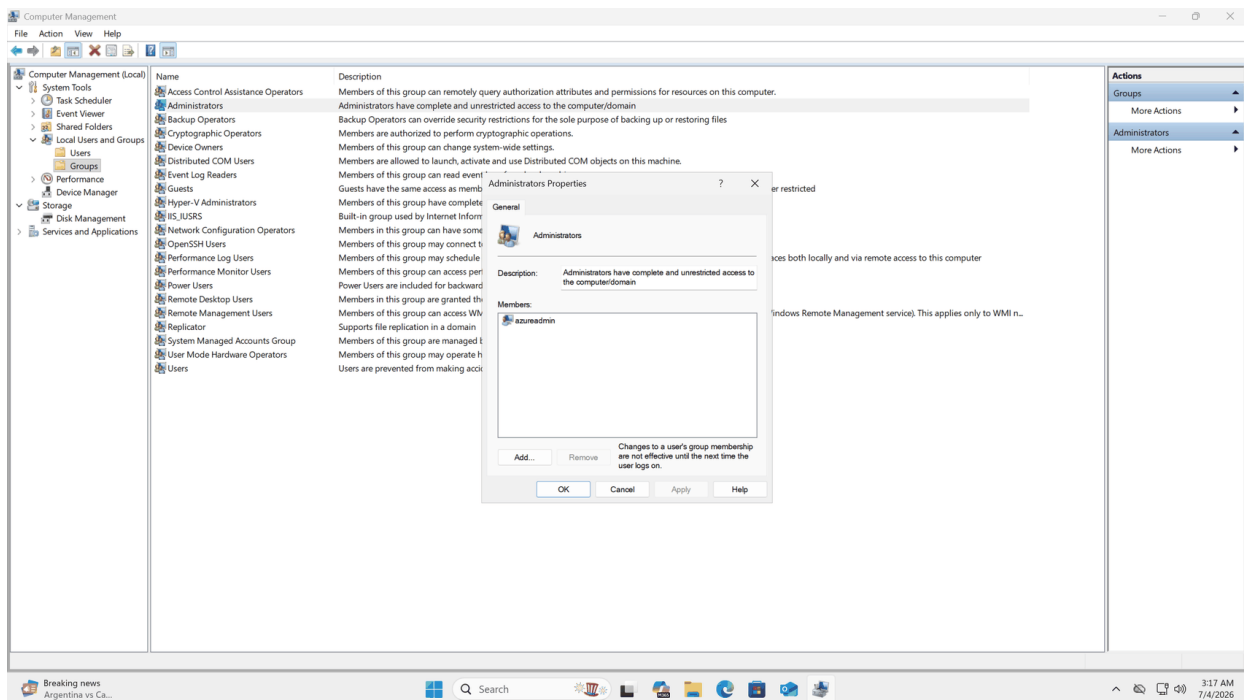
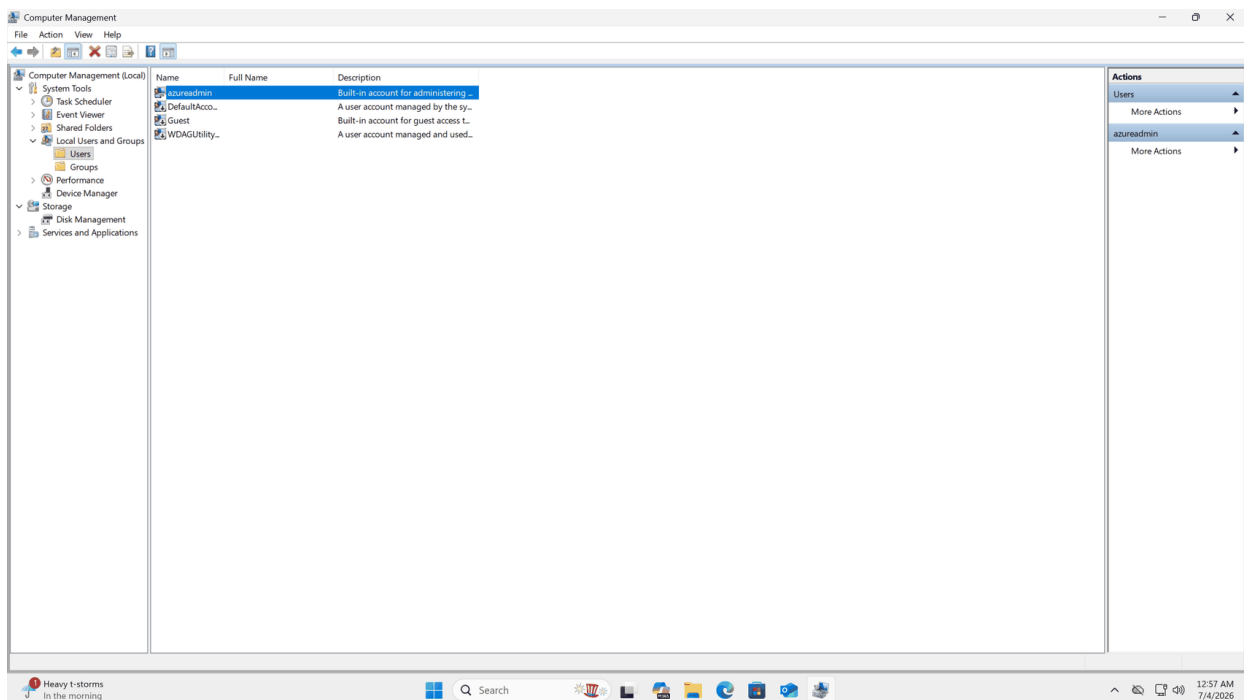
Connecting over RDP prompts for a username and password and nothing else. There is no second factor, no conditional access evaluation and no device compliance check standing between the internet and a local administrator session.



OS-level account confirmation

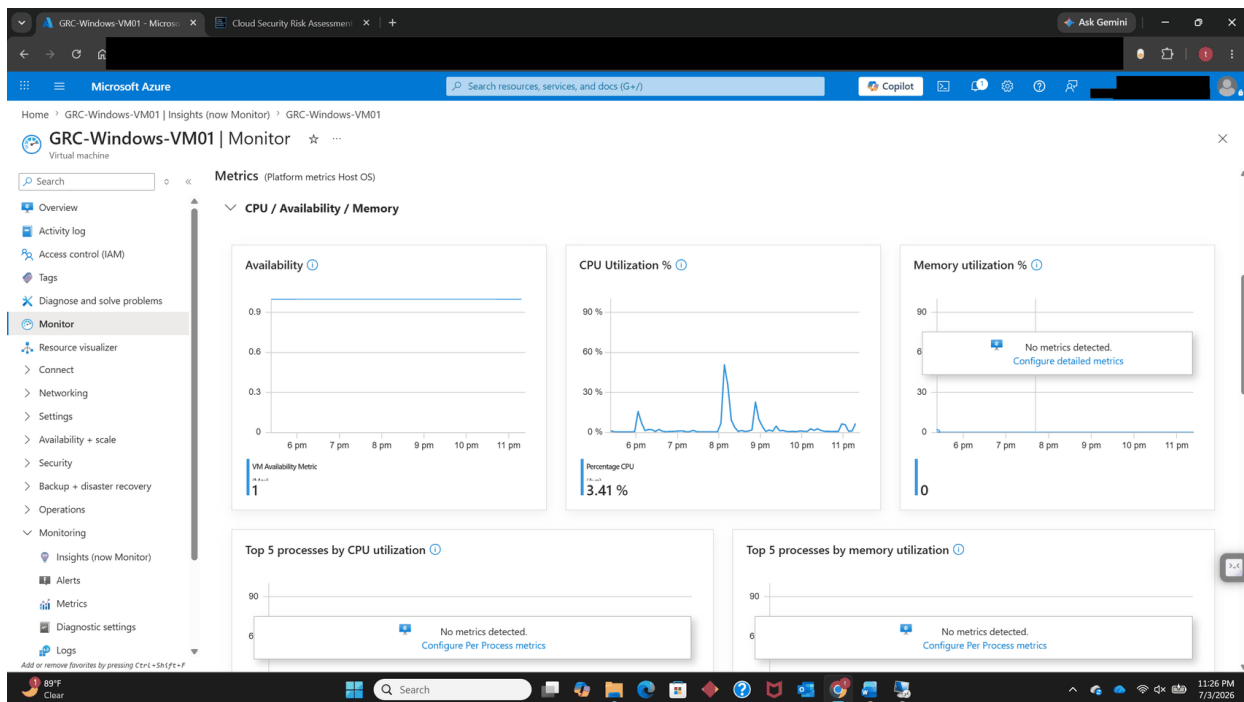
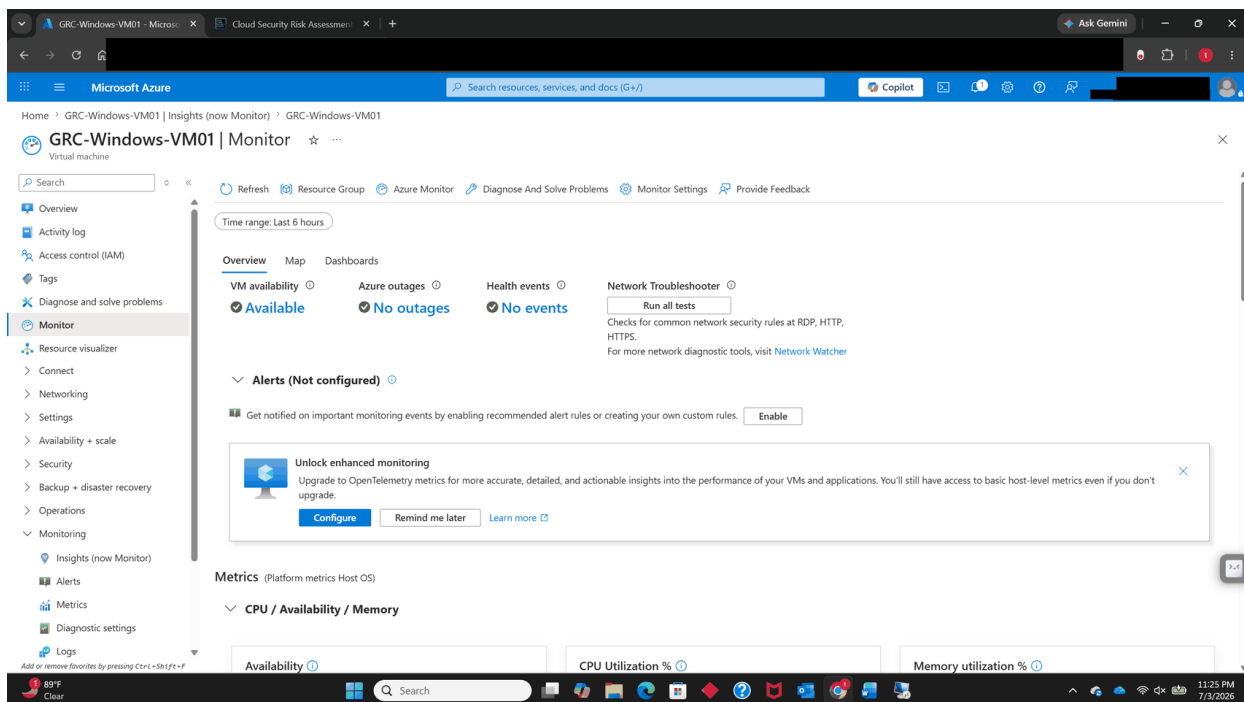
Inside the VM, Computer Management → Local Users and Groups → Users corroborates the Run Command output from within the operating system, and the Administrators group properties confirm azureadmin as its only member. Evidencing the same fact from two independent sources — the cloud control plane and the guest OS — is what makes the finding defensible in an audit.

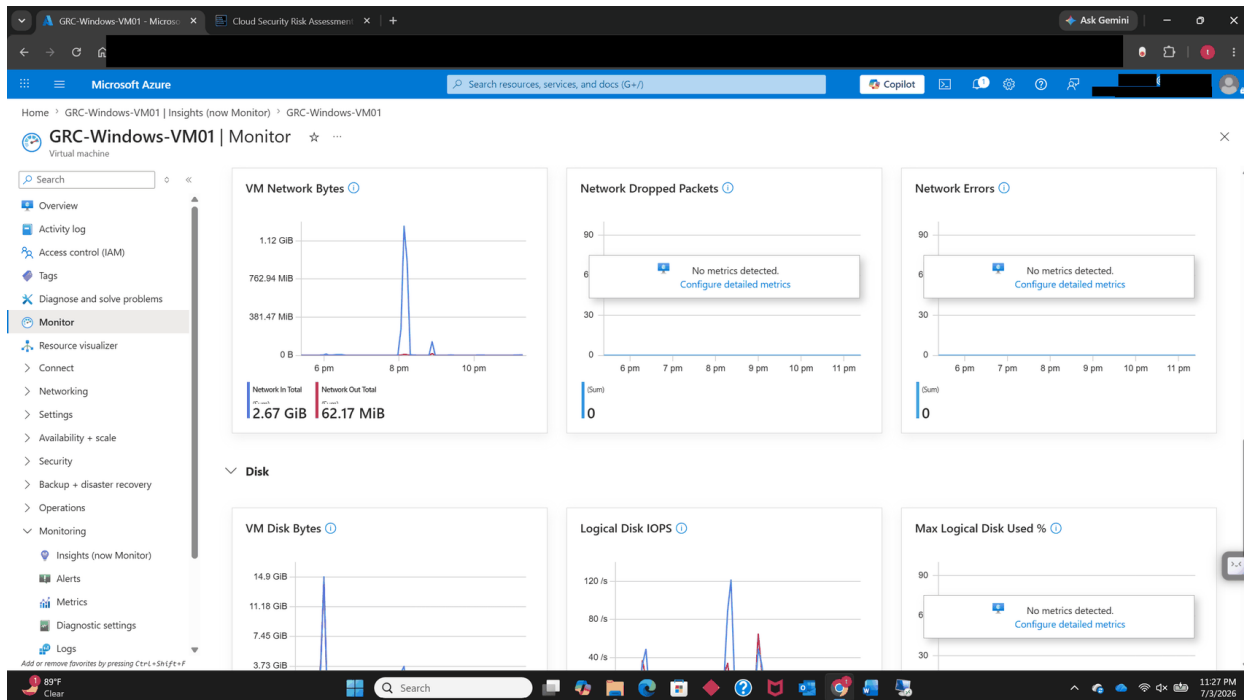
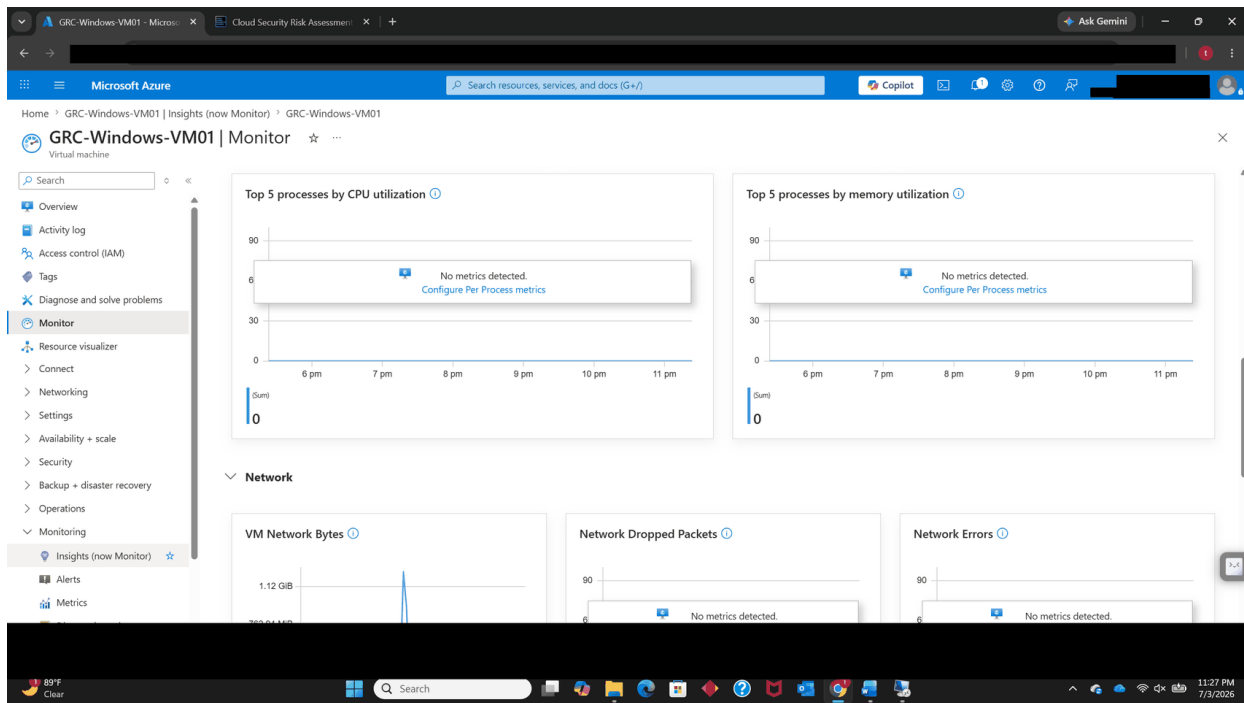


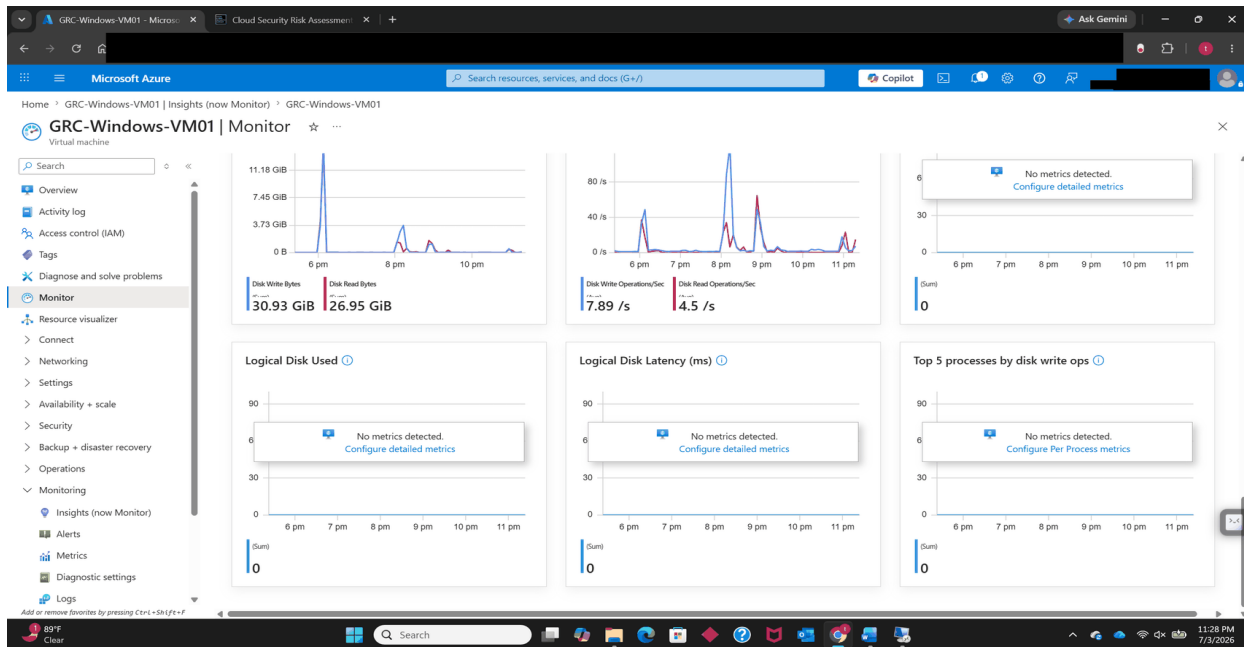
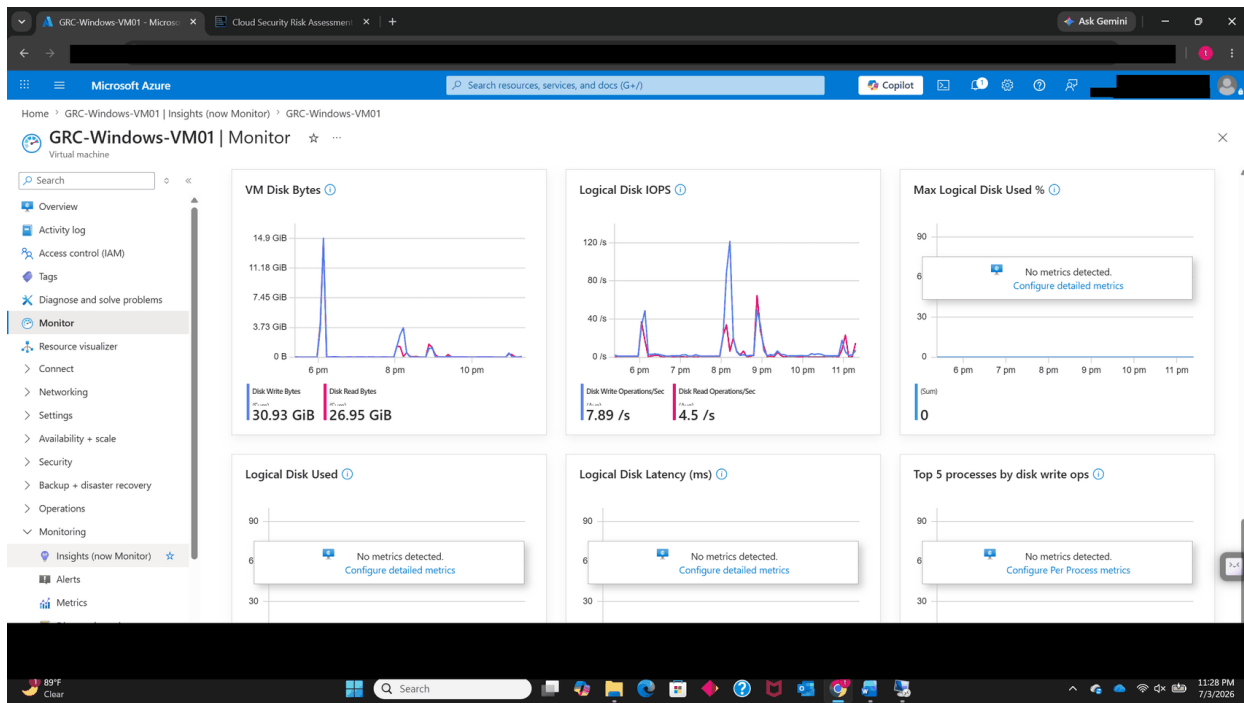


Monitoring coverage

Azure-side monitoring was checked first. Monitor (formerly Insights) returns platform metrics such as VM Network Bytes, VM Disk Bytes and Logical Disk IOPS, because those come from the hypervisor at no cost. Network Dropped Packets, Network Errors, Max Logical Disk Used %, Logical Disk Latency and Top 5 processes all return "No metrics detected — configure detailed metrics".



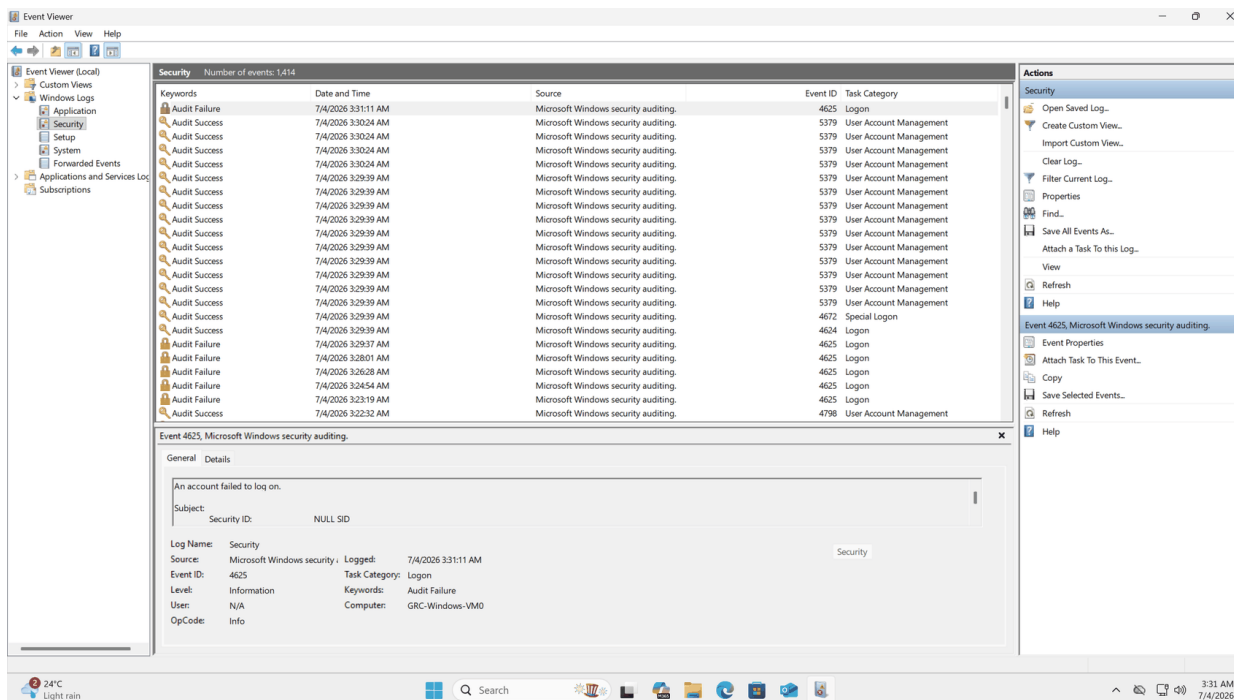
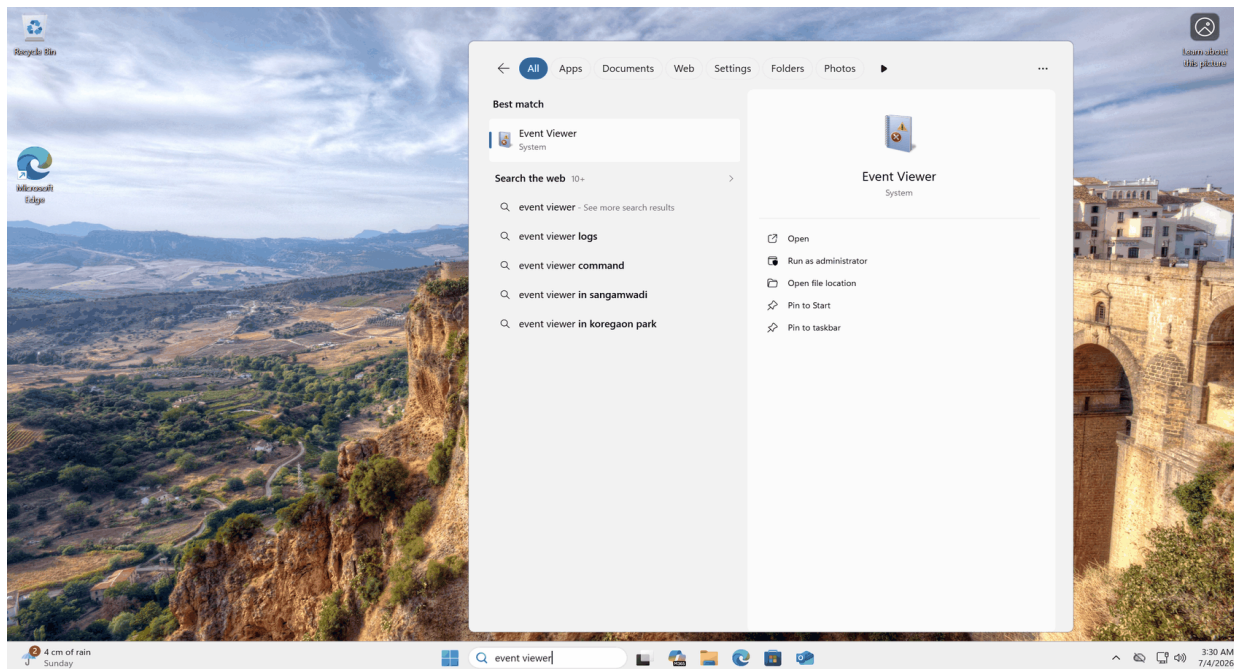




This partial coverage is worth naming precisely, because it is exactly the kind of thing that produces false assurance. Charts are drawn, so monitoring appears to be switched on. What is actually missing is guest-level telemetry, any log collection, and any alert rule. Nothing about this VM would ever notify a human.

OS-side Logging

OS-side logging was checked next. Event Viewer → Windows Logs → Security confirms the host is generating audit records — 1,414 events at the time of review.



Assuming default OS configuration unless hardened:

This assessment assumes a standard Windows 11 Pro installation with no security measures beyond what Azure and the operating system provide by default. There are no custom Group Policies, CIS Benchmarks or security standards in place. Windows Defender and Windows Firewall are enabled at their default settings, and no additional host-based security tooling has been installed.

Identified vulnerabilities

Identified Vulnerabilities		
Asset	Vulnerability	Evidence Observed
Virtual machine	RDP (TCP/3389) exposed to the internet	NSG rule "RDP", priority 300, Source: Any, Action: Allow — flagged by Azure with a warning icon
Authentication	No multi-factor authentication	RDP prompts for username and password only; no second factor or conditional access
Identity	Single administrator account	Get-LocalUser and Computer Management both show azureadmin as the only enabled account and sole member of Administrators
Operating system	Default hardening only	No security baseline, no Group Policy hardening, no VM extensions, unmanaged patch cadence
Monitoring	No centralised logging or alerting	Platform metrics only; detailed metrics report "No metrics detected"; no workspace, no alert rules
Network design	NSG bound to the network interface only	Portal reports "Impacts 0 subnets, 1 network interface"; effective security rules: 0
Egress	Unrestricted outbound access	Default rule 65001 AllowInternetOutBound permits all traffic to the internet
Recovery	No backup or recovery point	Backup + disaster recovery not configured; no vault, snapshot or resource lock
Data at rest	Encryption at host and integrity monitoring disabled	VM overview: Secure Boot enabled, vTPM enabled, integrity monitoring disabled

Step 2: Assign Risk Scores (Quantifying Risk)

Having identified the security observations, the next step is to quantify them. Risk scoring translates technical weaknesses into a form that leadership and stakeholders can understand and prioritise. Instead of calling something "high risk" subjectively, a repeatable model is applied so that any two findings can be compared consistently, even across different assets and threat types.

Risk Score = Likelihood × Impact, each scored from 1 to 5.

Likelihood scale

Likelihood measures how realistic a threat is in the current environment. It was assessed against four questions: is the asset reachable from the internet; how prevalent is the technique in the wild; can

exploitation be automated or does it require skill; and what preventive or detective controls already stand in the way.

Score	Rating	Meaning in this environment
1	Rare	No realistic path exists in the current configuration
2	Unlikely	Requires prior compromise or an already privileged position
3	Possible	Plausible, but depends on a specific condition such as an unpatched CVE
4	Likely	Commonly attempted and technically straightforward
5	Almost certain	Already observed occurring against this asset

Impact scale

Impact measures the consequence of successful exploitation: loss of confidentiality, integrity or availability; the level of access gained, user against administrator; operational disruption; and any compliance or reputational consequence. Impact rises where the affected asset carries elevated privilege or broad access.

Score	Rating	Meaning in this environment
1	Minimal	No meaningful loss of confidentiality, integrity or availability
2	Minor	Limited effect, easily reversed
3	Moderate	Noticeable loss, or detection and response are degraded
4	High	Loss of the asset, or user-level compromise of the host
5	Critical	Full administrative control, or compromise of the cloud control plane

Rating bands

1 – 5	6 – 10	11 – 15	16 – 25
Low	Medium	High	Critical

Risk Register

The risk register is the core GRC artefact this assessment produces. It converts the assets, threats and vulnerabilities identified in Step 1 into measurable, prioritised risks that management can act on.

ID	Asset	Threat	Likelihood	Impact	Risk Score	Rating
R-01	RDP endpoint (TCP/3389)	Automated brute-force / password spray	5	4	20	Critical
R-02	azureadmin local administrator	Credential compromise → full system control	4	5	20	Critical
R-03	Windows 11 Pro guest OS	Exploitation of unpatched vulnerabilities	3	4	12	High
R-04	Windows Security event log	Undetected intrusion; loss of evidence	4	3	12	High
R-05	Subscription / resource group	Privilege misuse on the management plane	2	5	10	Medium

ID	Asset	Threat	Likelihood	Impact	Risk Score	Rating
R-06	Virtual network segmentation	Lateral movement after compromise	2	4	8	Medium
R-07	Outbound network path	C2 beaconing / data exfiltration	2	4	8	Medium
R-08	VM availability	Destructive event with no recovery point	2	4	8	Medium
R-09	OS disk and boot integrity	Offline disk access / boot tampering	1	3	3	Low

Risk profile: 2 Critical, 2 High, 4 Medium, 1 Low.

Scoring Justifications

Justification is what makes a register auditable. Scores must be supported, not assumed.

Risk	Justification
R-01	Likelihood 5. Exposure here is measured rather than assumed: the Windows Security log recorded repeated Event ID 4625 failed logons with a NULL SID at intervals of 93 to 96 seconds within hours of deployment. Impact 4, because successful authentication yields an interactive host session but not control-plane access.
R-02	Likelihood 4. The account name is predictable, the endpoint is internet-reachable, and no MFA or lockout control was observed. Impact 5, because Administrators hold complete and unrestricted access, so compromise is total loss of confidentiality, integrity and availability for the asset.
R-03	Likelihood 3. Exploitation requires a specific unpatched CVE rather than a guessed password, but an unmanaged patch cadence leaves exposure windows open-ended. Impact 4, because most privilege-escalation chains on this host end at SYSTEM.
R-04	Likelihood 4. Malicious activity is already present in the log and nothing is configured to surface it to a human. Impact 3, because absence of detection causes no loss directly, but extends dwell time and destroys evidence when the host is rebuilt or the log rolls over.
R-05	Likelihood 2. The management plane is guarded by the identity provider rather than by an exposed port, and the lab has a single trusted operator. Impact 5, because control-plane compromise permits snapshot exfiltration, extension-based code execution and deletion across the subscription.
R-06	Likelihood 2. A single workload means there is little to move laterally toward today. Impact 4, because NIC-only enforcement removes a defence-in-depth layer that would contain an intrusion once the estate grows.
R-07	Likelihood 2, realised only after a successful initial compromise. Impact 4, because unrestricted egress lets an attacker establish command and control and move data out without encountering a single control.
R-08	Likelihood 2 in a lab holding no production data. Impact 4, because with no recovery point the only response to a destructive event is a full rebuild and all host state is permanently lost.
R-09	Likelihood 1. Azure managed disks are already encrypted at rest with platform-managed keys, and Secure Boot with vTPM is active. Impact 3, and the residual gap is customer key ownership and lost attestation alerting rather than plaintext data. Retained as an accepted risk for lab scope.

R-09 is deliberately rated Low and explicitly accepted rather than escalated. A register in which every finding is Critical directs attention nowhere and tends not to be acted upon; the discipline of a risk assessment lies in scoring proportionately and being able to defend each number, including the low ones.

Step 3: Map Controls to Policies and Frameworks

This step answers the question: what controls reduce this risk, and what standards do they satisfy? Rather than proposing ad-hoc fixes, the aim is that every security control can be justified, audited and traced back to an established standard.

Framework selection

The NIST Cybersecurity Framework provides a structured, risk-based way to link technical weaknesses to governance and compliance obligations, which helps justify security decisions to non-technical stakeholders. The CIS Critical Security Controls provide prescriptive guidance for mitigating the specific attack vectors present here — exposed RDP, credential theft, missing logging, unpatched systems and excessive privilege. Used together, they ensure the controls implemented are aligned to recognised standards and are auditable, rather than assembled from preference or from whatever tooling happened to be available.

Control categories

- Preventive controls stop an attack before it succeeds, such as restricting access to a critical service or enforcing multi-factor authentication.
- Detective controls identify and alert on suspicious or malicious activity, such as centralised logging or intrusion detection.
- Corrective controls reduce the impact after an incident, such as applying patches or restoring a compromised system.

After selecting a control, it is mapped to an industry framework so that it is auditable and traceable. What matters is whether the control meets the framework's intent, not the specific tool used to implement it. In GRC and compliance contexts, traceability and alignment matter more than the technology.

Control Mapping Table

Risk	Recommended Control	Control Type	NIST CSF 1.1	CIS Controls v8
R-01	Restrict the NSG inbound source from Any to a trusted IP or CIDR; move to Azure Bastion or Just-in-Time VM access	Preventive	PR.AC-3; PR.PT-4	4.6; 12.7
R-02	Require MFA for administrative access; create a named admin account; enforce an account lockout policy	Preventive	PR.AC-1; PR.AC-7	5.4; 6.5
R-03	Azure Update Manager schedule; security baseline through Azure Policy guest configuration	Corrective	PR.IP-1; PR.IP-12	4.1; 7.3
R-04	Log Analytics workspace; Defender for Servers; alert rule on Event ID 4625 volume	Detective	DE.CM-1; DE.AE-3	8.9; 13.1
R-05	Least-privilege Azure RBAC; Entra PIM just-in-time elevation; resource locks	Preventive	PR.AC-4; ID.GV-2	5.1; 6.8
R-06	Attach an NSG at subnet level in addition to the NIC; use Application Security Groups	Preventive	PR.AC-5	12.2; 4.4
R-07	Egress filtering through Azure Firewall; enable NSG flow logs	Preventive / Detective	PR.PT-4	13.6; 12.2

Risk	Recommended Control	Control Type	NIST CSF 1.1	CIS Controls v8
R-08	Azure Backup with a Recovery Services vault; vault soft delete; delete lock	Corrective	PR.IP-4; RC.RP-1	11.2; 11.3
R-09	Enable encryption at host; enable Trusted Launch integrity monitoring	Preventive / Detective	PR.DS-1	3.11; 4.1

Framework identifiers follow NIST Cybersecurity Framework 1.1, matching the assessment brief. Under CSF 2.0 the PR.AC category has been reorganised into PR.AA (Identity Management, Authentication and Access Control), and much of PR.IP now falls under PR.PS (Platform Security). CIS references are to Controls v8 safeguards.

Step 4: GRC Risk Assessment Report

This step consolidates the findings — assets, threats, vulnerabilities, risk scores and controls — into a professional GRC-style report, written to be readable by both technical and non-technical stakeholders.

1. Executive Summary

This report summarises a cloud security risk assessment conducted on a single Azure-hosted virtual machine from a Governance, Risk and Compliance perspective. The goal was to identify critical assets, evaluate potential threat scenarios, assess vulnerabilities, quantify risk, and recommend security controls aligned with recognised industry frameworks.

Nine risks were identified: two Critical, two High, four Medium and one Low. The overall risk posture of the assessed environment is High. The environment is small, but the combination of an internet-reachable administrative entry point, single-factor authentication and no detection capability means a single successful credential guess would produce complete and unobserved compromise of the host.

The findings centre on exposed remote access, the absence of multi-factor authentication, default operating system hardening and limited centralised monitoring. These are not exotic issues; they are the cloud misconfigurations that appear most often in real assessments, and the reason they matter is set out in the key finding below.

2. Scope and Environment

- A single Azure virtual machine and the resources Azure created alongside it
- The local identity store on that machine and the subscription control plane surrounding it
- No additional cloud services, applications or workloads
- Assessment performed from a GRC, non-exploitative perspective: configuration review and native logging only

Full environment details are given in the Lab Environment table at the start of this document.

3. Asset, Threat and Vulnerability Summary

Asset	Threat	Vulnerability	Why It Matters
Azure virtual machine	Brute-force attack	RDP exposed to the internet	Easy remote entry point for attackers
azureadmin account	Credential theft	No MFA; sole enabled account	Full system compromise possible
Guest operating system	Exploitation of a known CVE	Default hardening; unmanaged patching	Common Windows attack vector
Security event log	Undetected attack	No centralised logging or alerting	Delayed detection and lost evidence
Azure subscription	Privilege misuse	Standing privilege on one identity	High impact if misused
Network segmentation	Lateral movement	NSG bound to the NIC only	No containment as the estate grows
Outbound path	Data exfiltration	Unrestricted egress to the internet	No control on the way out
VM availability	Destructive event	No backup or recovery point	Rebuild is the only response

4. Risk Prioritisation

Risks were scored using the Likelihood × Impact model defined in Step 2 and are recorded in full in the risk register above, giving a profile of two Critical risks, two High, four Medium and one Low, and an overall risk posture of High.

5. Security Controls and Compliance Mapping

Each identified risk was matched to a preventive, detective or corrective control and mapped to NIST CSF 1.1 and CIS Controls v8 in the control mapping table above.

6. Recommended Mitigation Actions

Priority 1 — immediate

1. Change the NSG rule "RDP" (priority 300) source from Any to a specific trusted IP address or CIDR range. One field, and it removes the exposure driving both Critical risks.
2. Deploy Azure Bastion, or enable Just-in-Time VM access, so that TCP/3389 is not permanently open to any network.
3. Require multi-factor authentication for administrative access, and create a named administrative account in place of the default azureadmin.
4. Route the VM's Security event logs to a Log Analytics workspace and configure an alert rule on Event ID 4625 volume, so that failed-logon bursts reach a human.

Priority 2 — within 30 days

1. Enrol the VM in Azure Update Manager with a recurring maintenance window, and apply a security baseline through Azure Policy guest configuration.
2. Replace standing privileged access with Entra Privileged Identity Management just-in-time elevation, and apply a delete lock to the GRC-Lab resource group.
3. Configure Azure Backup with a Recovery Services vault, a daily policy and vault soft delete enabled.

Priority 3 — within 90 days

1. Attach a network security group at subnet level in addition to the network interface, and express workload intent through Application Security Groups.
2. Constrain outbound traffic through NSG destination rules or Azure Firewall FQDN filtering, and enable NSG flow logs.

7. Known Limitations

Stating the boundaries of an assessment is part of the deliverable, not a qualification of it.

- Source addresses for the Event 4625 records were not captured, so the failed logons are consistent with automated attempts but are not confirmed as external in origin.
- This is a point-in-time review; no configuration-drift monitoring or continuous compliance scanning was in place.
- No exploitation was performed, by design. Vulnerability presence is inferred from configuration and vendor documentation rather than demonstrated.
- Scope covers a single workload, so segmentation risk is assessed against a hypothetical future estate rather than an observed one.
- No data classification was performed; impact scores assume the host holds no regulated or production data.

8. Overall Risk Posture

The overall risk posture of the assessed environment is High. The environment is small, but size does not reduce exposure. An internet-reachable administrative entry point, protected by a single factor, on a host with no detective capability, is the configuration that produces the majority of cloud intrusions in practice. Observed authentication attempts within hours of deployment confirm the exposure is live rather than latent. Retiring the two Critical risks requires four actions, one of which is a single field change; addressing the two High risks brings the environment to a posture appropriate for its purpose.

Key Finding: Automated Authentication Attempts Against Exposed RDP

The lab was deployed with RDP open to Source: Any, exactly as the brief intended. Within hours of deployment the virtual machine's own Security log had recorded a pattern that turns the central risk of this assessment from a textbook example into a measured observation.

Time (local)	Event ID	Result	Task category
03:23:19	4625	Audit Failure	Logon
03:24:54	4625	Audit Failure	Logon
03:26:28	4625	Audit Failure	Logon
03:28:01	4625	Audit Failure	Logon
03:29:37	4625	Audit Failure	Logon

Time (local)	Event ID	Result	Task category
03:31:11	4625	Audit Failure	Logon

Event ID 4625 is "An account failed to log on." Every entry carried Subject → Security ID: NULL SID and User: N/A, meaning the logon failed before any account context was established — the signature of an authentication attempt against a service rather than a mistyped password at a console. The intervals between them are 95, 94, 93, 96 and 94 seconds. That regularity does not come from a person.

Root cause

When the virtual machine was created, the Azure wizard offered to open inbound RDP on port 3389 with the source set to Any, and that default was accepted so the lab could be reached remotely. That configuration exposed the host directly to the public internet. The machine had no DNS name, hosted no application, was advertised nowhere, and had existed for a matter of hours. Automated scanners located it independently. Internet-facing RDP does not wait to be discovered.

What this justifies, and what it does not

It justifies scoring R-01 at likelihood 5 rather than 4. The exposure produced observable activity almost immediately, so this is not a risk that might materialise — on this host it began at once.

It does not justify calling this a confirmed attack. The Source Network Address field in each event's Details tab was not captured during the assessment. Without it, the attempts cannot be attributed to an external origin with certainty; a misconfigured local RDP client could in principle produce a comparable pattern. The finding is therefore recorded as consistent with automated authentication attempts, and capturing those source addresses is the first item under Known Limitations.

Remediation

The immediate control is to change the network security group inbound rule for port 3389 from Source: Any to a single administrative IP address or CIDR range, which removes the host from the population that internet-wide scanners enumerate. Controls appropriate to a production environment would go further:

- Removing public RDP exposure entirely in favour of Azure Bastion, a VPN or Just-in-Time VM access
- Enforcing an account lockout policy so that repeated failures disable the target account
- Enabling multi-factor authentication for all remote administrative access
- Alerting on failed-logon rate thresholds rather than reviewing logs after the fact

GRC and SOC relevance

This single finding exercises the whole chain that a GRC function exists to produce: an observation in a log, quantified into a scored risk with a written justification, mapped to a control that satisfies a recognised framework, prioritised against other risks competing for the same budget, and documented so

that the decision survives an audit. It also shows why Event ID 4625 is monitored by rate rather than by individual occurrence — one failed logon is routine, while one every ninety-five seconds is an incident.

Summary

By completing this project, I learned to:

- Set up a cloud-based lab environment in Microsoft Azure by creating a resource group and deploying a Windows virtual machine to serve as the assessment scope.
- Identify and document critical assets, threats and vulnerabilities within a cloud-hosted virtual machine, applying core Governance, Risk and Compliance principles, and gather the supporting evidence from both the Azure control plane and the guest operating system.
- Quantify cybersecurity risk using a structured Likelihood × Impact methodology, and write a defensible justification for every score rather than asserting a rating.
- Map technical security controls to recognised industry frameworks — the NIST Cybersecurity Framework and the CIS Critical Security Controls — demonstrating governance and compliance alignment.
- Produce a professional GRC-style risk assessment report containing an executive summary, risk register, control mappings and actionable, prioritised mitigation recommendations.
- Translate technical findings into business risk, state the limits of the evidence honestly, and support audit readiness, risk communication and informed security decision-making.
- Redact evidence properly before publication, applying the redaction to the image data itself so that identifiers cannot be recovered from the published file.